



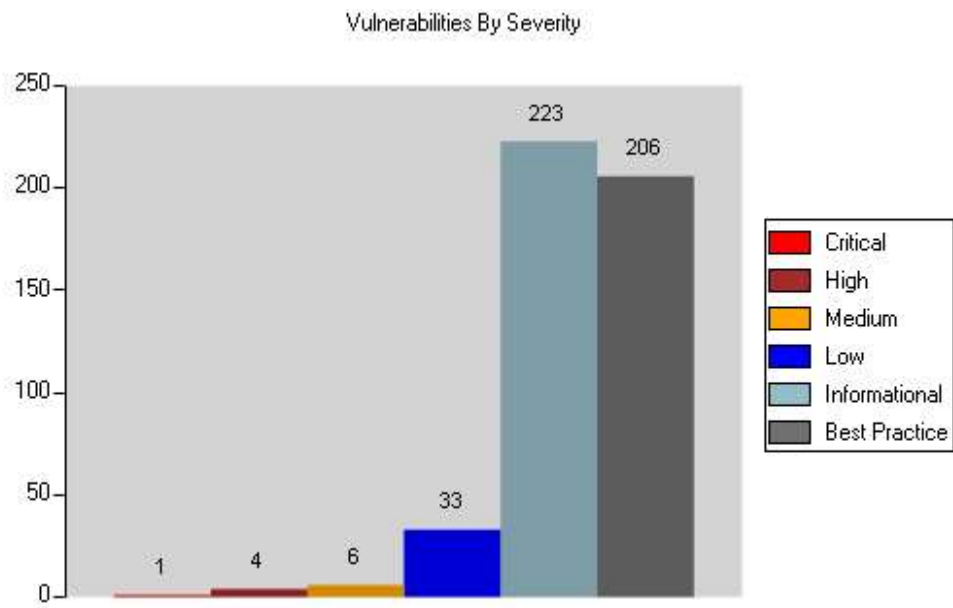
OpenText DAST

Vulnerability (Legacy)

Web Application Assessment Report

Scan Name:	Site: https://bizsmsraz.telekom.rs/_Scan-2	Crawl Sessions:	478
Policy:	Standard	Vulnerabilities:	44
Scan Date:	4/16/2026 8:45:07 AM	Scan Duration:	42 minutes : 24 seconds
Scan Version:	25.4.0.57	Client:	FF59
Scan Type:	Site		

Server: https://bizsmsraz.telekom.rs:443



Critical

Insecure Deployment: HTTP Request Smuggling

Summary:

WebInspect has detected the application to be vulnerable to an HTTP Request Smuggling attack.

HTTP Request Smuggling vulnerabilities arise due to the discrepancy in parsing of non-compliant HTTP headers by the front-end and back-end servers. By supplying a request that is interpreted as being of different lengths by different servers, an attacker can poison the back-end TCP/TLS socket and prepend arbitrary data to the next request or smuggle additional requests to the back-end server without the front-end server being aware of it.

There are numerous ways in which a malicious user can accomplish an HTTP Request Smuggling attack. In this instance, an incoming HTTP request that contains both Content-Length and Transfer-Encoding headers is interpreted differently by the front-end server and the back-end server. One honors the Content-Length header and the other the Transfer-Encoding header to determine the length of the request. This can render the application vulnerable to smuggling attacks.

The attack vector used indicates that the front-end server honors the Content-Length header and the back-end server honors the Transfer-Encoding header.

WebInspect was able to confirm this vulnerability. WebInspect performed the attack by sending two requests on the same TCP/IP connection with the server. The first request with HTTP headers

```
Content-Length: 26
Transfer-Encoding: chunked
and request body
```

```
0ATTK / HTTP/1.1Q: W
```

was crafted so that the server put part of the request body in a queue. This was prepended to the subsequent HTTP request and caused an error on the server.

Execution:

The Request Smuggling check accuracy might be impacted if the server is processing multiple requests, or if there are multiple servers behind a load balancer. The load balancer might send attack and verification requests to different backend servers and that would fail to flag the issue correctly. We recommend that you re-scan with a policy that contains only this check. Enable the traffic monitor.

Inspect the traffic monitor logs for the resulting scan if the vulnerability was flagged. Enable the column Scan.CheckID in the column view and filter on check ID 11613 to only see the traffic generated for this check.

Locate a POST request with both Content-Type and Transfer-Encoding headers and the mentioned request body. The values

of these two headers is crafted so that the server put the value

ATTN / HTTP/1.1Q: W

in a queue and it is prepended to next incoming request. With this malformed start of the next HTTP request, the server is expected to respond with an error response on the normal HTTP request. This request and the response should be visible in the traffic log after the request with the attack.

Implication:

Malicious users can use the HTTP Request Smuggling vulnerability to bypass front-end security rules, access internal systems, and poison web caches. In addition, it can also be exploited to steal user information and launch cross-site scripting attacks.

Fix:

Fix this vulnerability by implementing one of the following:

- Configure the front-end server to exclusively use HTTP/2 to communicate to back-end systems.

- Disable back-end connection reuse.

- Ensure all servers in the chain run the same webserver software with the same configuration.

- Configure the back-end server to reject ambiguous HTTP requests, such as those that contain both Content-Length and Transfer-Encoding headers, and close the TCP/TLS connection.

Reference:

[CWE 444 - HTTP Request Smuggling](#)

[OWASP - HTTP Request Smuggling](#)

[HTTP Desync Attacks: Request Smuggling Reborn](#)

[HTTP Request Smuggling in 2020 – New Variants, New Defenses and New Challenges](#)

Attack Request:

```
POST /Content/9b6893css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOu001 HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: https://bizsmsraz.telekom.rs/
Content-Length: 26
Content-Type: application/x-www-form-urlencoded
Pragma: no-cache
Transfer-Encoding: chunked
Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
Category="Audit.Attack";SID="70BD100FF6DBE5425F344FCDC03F9A60";PSID="688041F6CB57E219A4FD625042D569D2";SessionType="AuditAttack";CrawlType="None";AttackType="HeaderParamManipulation";OriginatingEngineID="448ed5f3-d41b-4893-ae3d-7ec4afd3ed22";AttackSequence="0";AttackParamDesc="";AttackParamIndex="-1";AttackParamSubIndex="-1";CheckId="11613";Engine="Http+Request+Smuggling";SmartMode="4";tht="40";
X-RequestManager-Memo: stid="1201";stmi="0";sc="1";rid="b7410de0";
X-Request-Memo: rid="a74aebf2";sc="1";thid="757";
Cookie: __RequestVerificationToken=7U2MSLaTAvj9I0v5uaBcj3-JKLqNaQxWnWyNkyX8bQo4Lzv2aAp3xih0H3ZyAdxF92Xw2P-TZcHP2T5lXhIFGyOQKn_OXGyMHiMTAYd7ZM01;CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;.AspNet.ApplicationCookie=O1hyY_IkiL0NjzvZq82P0_O3p8Fua4jD1XKb3edmy2zrYftH4gcYBm9J5q8J3Ths2DW8NZG2ifdPxRBoWkIISuqi-Csqert5rCr2lbdw0xLLD2lczNCE9FkiyaDHCY96xSEvdsK-RrCUm_J3Pa0AawRei6sbYx-c2G2aY8qnOnkvma3P3boY5LEC2Q30dOUksazKmYK6dwOffmMmb8tZzFtLOY0zd1u2y_MirgXhn-QS0_sZUSeehfD2oGgbXK0Bkv5n2SMQ4dpjpgT51eqg_JvhXQMvK9Ju_5vRYO6xa0iyejZeAtoZiIgEDjbfGShVrZQ7PN_6rmne0h2gzZD-ZJ6WaTXkS0aOb1wzXHxokR5t_PcfcPOpznSnFysx8IE4lsR9t_yZC5Nv7c1F4P3JtVpohTpwtf6KaZ4TAa3KdZArZtxOuMihLnY1Jdzhk3NFYuisaHqsC1bP1jI2nl7gYb7e6Nsi3O7Em_64tf_RaaqPfZoazD_HFPVWss7aLUWBfHNNerDR14iuR1isRQK0uw;.AspNet.TwoFact orCookie=RyKlujZ9EITP0vFdxJ9mVR5Avkwg26EorBC1r_qyVj2XcsVWzqS5AQw9el5Gm72w7YhcDgWTgc41Dbaa5RTfaK_eJ15NdDmsHI4K5B61ts0F8pZ_OIEtU2hNrJZgkcz1CnO99xCBujI6rSjrJblCKI5m3chJHvzABvL7IN1kmhZU7yg1CldQnAZh5_IGSadKfb_gfHTYUfC48DjOfLz_7UpdSAdKi36Vcryc3egcr_rKY_8yFO7IsEikb6-QtpW0fAn0I9teO3PxzbIz7fDW5pgSPIvrAIXGLwQ97zb_xMI5XEnV7pibpp6Zydz41l8bQXwaagBVRESdsKCFI2y9jg
Sec-Fetch-Dest: style
Sec-Fetch-Mode: no-cors
Sec-Fetch-Site: same-origin
Priority: u=2

0
```

Attack Response:

```
HTTP/1.1 404 Not Found
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
```

X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:55:58 GMT
Content-Length: 2470

```
TYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Page not found</title>
  <link href="/Content/css?v=YXE83-P21orHp...TRUNCATED...src="/bundles/jquery?v=IAWanvxuK91VI6uSCdWzhvtofm0aK0rptSpK6X6X2d01"></script>

  <script src="/bundles/jqueryval?v=h...TRUNCATED...
```

File Names:

- <https://bizsmsraz.telekom.rs:443/Content/9b6893css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01>

High

Insecure Transport: Weak SSL Cipher

Summary:

WebInspect has detected support for weak TLS/SSL ciphers on the server **<https://bizsmsraz.telekom.rs:443/>**. A weak cipher suite is one that uses a cryptographic algorithm that does not provide adequate security. This could be because the algorithm is outdated, or because it has been shown to be vulnerable to certain types of attacks that are not trivial.

The Transport Layer Security (TLS) and Secure Sockets Layer (SSL) protocols provide a mechanism to help protect authenticity, confidentiality, and integrity of the data transmitted between a client and web server. The strength of this protection mechanism is determined by the authentication, encryption, and hashing algorithms. These are collectively known as a cipher suite - chosen for the transmission of sensitive information over the TLS/SSL channel. Most web servers support a range of such cipher suites of varying strengths. Using a weak cipher or an encryption key of insufficient length, for example, could enable an attacker to defeat the protection mechanism and steal or modify sensitive information.

If misconfigured, a web server could be manipulated into choosing weak cipher suites. Also, new versions of the TLS protocols are backward compatible and provide support for older cipher suites defined in previous versions of the SSL/TLS protocols. For example, it is possible to configure TLS 1.2 to use older and weak ciphers that use CBC.

We recommend updating the web server configuration to remove weak ciphers and to always choose the strongest ciphers for encryption.

Execution:

Each weak cipher was detected by establishing an SSL connection with the target host and specifying the cipher to test in the Client Hello message of the SSL handshake.

Implication:

A weak encryption scheme can be subjected to brute force attacks that have a reasonable chance of succeeding using current methods and resources. An attacker could possibly execute a man-in-the-middle attack which would allow them to intercept, monitor and tamper with sensitive data.

Fix:

Disable support for weak ciphers on the server. Weak ciphers are generally defined as:

- Any cipher with key length less than 128 bits
- Cipher suites that do not have Perfect Forward Secrecy (PFS)
- All CBC mode ciphers due to POODLE, Zombie POODLE, GOLDENDOODLE, 0-Length OpenSSL, and Sleeping POODLE vulnerabilities
- All ciphers that use SHA1 for cryptographic hash functions

The following ciphers supported by the server are weak and should be disabled:

- **TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)**
- **TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)**
- **TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)**
- **TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)**

- For Apache, modify the following lines in httpd.conf or ssl.conf:
- SSLCipherSuite ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:ECDHE-ECDSA-AES256-GCM-
- For Nginx, modify the following lines in nginx.conf or ssl.conf:
- ssl_ciphers ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256:ECDHE-ECDSA-AES256-GCM-
- For IIS, refer to the following Microsoft Knowledge Base articles:
 - Article ID: 187498
 - Article ID: 245030 and
 - Security Guidance for IIS
 - Article ID: 2868725
- For other servers, refer to vendor specific documentation or use Mozilla SSL Configuration Generator - <https://ssl-config.mozilla.org/>.

The following ciphers supported by the server should provide adequate protection and are safe to leave enabled:

- **TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)**
- **TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)**

Reference:

Transport Layer Security Cheat Sheet

https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html

PCI DSS v4.0

https://docs-prv.pcisecuritystandards.org/PCI%20DSS/Standard/PCI-DSS-v4_0.pdf

CVE-2013-2566

<https://nvd.nist.gov/vuln/detail/cve-2013-2566>

CVE-2016-2183

<https://nvd.nist.gov/vuln/detail/CVE-2016-2183>

CVE-2016-6329

<https://nvd.nist.gov/vuln/detail/CVE-2016-6329>

NIST Special Publication 800-131A Revision 2

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-131Ar2.pdf>

Microsoft:

Microsoft Security Advisory 2868725

<https://learn.microsoft.com/en-us/security-updates/SecurityAdvisories/2013/2868725>

Transport Layer Security (TLS) best practices with .NET Framework

<https://learn.microsoft.com/en-us/dotnet/framework/network-programming/tls>

TLS Registry Settings (Windows Server)

<https://learn.microsoft.com/en-us/windows-server/security/tls/tls-registry-settings>

Security Guidance for IIS

[https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2008-r2-and-2008/dd450371\(v=ws.10\)](https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2008-r2-and-2008/dd450371(v=ws.10))

SSL/TLS Strong Encryption: FAQ Apache
https://httpd.apache.org/docs/2.4/ssl/ssl_faq.html

New RC4 Attack
https://www.schneier.com/blog/archives/2013/03/new_rc4_attack.html

On the Practical (In-)Security of 64-bit Block Ciphers: Collision Attacks on HTTP over TLS and OpenVPN
<https://dl.acm.org/doi/10.1145/2976749.2978423>

The first collision for full SHA-1
<http://shattered.io/static/shattered.pdf>

RFC 6151: Updated Security Considerations for the MD5 Message-Digest and the HMAC-MD5 Algorithms
<https://datatracker.ietf.org/doc/html/rfc6151>

Attack Request:

```
GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: std="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
```

Attack Response:

```
HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
Set-Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; path=/; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:48:49 GMT
Content-Length: 4713

<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Prijava</title>
  <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOu001" rel="stylesheet"/>

  <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">
```

```

</ul>

<ul class="nav navbar-nav navbar-right">

  <li><a href="/" id="loginLink">Prijava</a></li>
  <li style="padding-bottom:11px; padding-top:11px;">|</li>
  <li>
    <a href="/Home/SetCulture?culture=en-us">
      <span class="flag-icon flag-icon-gb"></span>
    </a>
  </li>
</ul>

</div>
</div>
</div>
<div class="container body-content">

<h2>Prijava</h2>
<div class="row">
  <div class="col-md-12">
    <section id="loginForm">
<form action="/" class="form-horizontal" method="post" role="form"><input name="__RequestVerificationToken"
type="hidden" value="QIQ8mRUTN0iee6LdzuqQ6IszC6bfJO4waM0QZzJhxle-
QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZC139FMpTFT15TmpXQjCKNKZ881" />      <hr />
    <div class="form-group">
      <label class="col-md-2 control-label" for="Username">Korisničko ime</label>
      <div class="col-md-10">
        <input class="form-control" data-val="true" data-val-required="Korisničko ime je obavezno polje"
id="Username" name="Username" type="text" value="" />
        <span class="field-validation-valid text-danger" data-valmsg-for="Username" data-valmsg-
replace="true"></span>
      </div>
    </div>
    <div class="form-group">
      <label class="col-md-2 control-label" for="Password">Lozinka</label>
      <div class="col-md-10">
        <input class="form-control" data-val="true" data-val-required="Lozinka je obavezno polje" id="Password"
name="Password" type="password" />
        <span class="field-validation-valid text-danger" data-valmsg-for="Password" data-valmsg-
replace="true"></span>
      </div>
    </div>
    <div class="form-group">
      <div class="checkbox">
        <input data-val="true" data-val-required="The Zapamti me? field is required." id="RememberMe"
name="RememberMe" type="checkbox" value="true" /><input name="RememberMe" type="hidden" value="false" />
        <label for="RememberMe">Zapamti me?</label>
      </div>
    </div>
    <div class="form-group">
      <div class="col-md-offset-2 col-md-10">
        <input type="submit" value="Prijava" class="btn btn-default" />
      </div>
    </div>
  </div>
</div>
...TRUNCATED...

```

File Names: ● <https://bizsmsraz.telekom.rs:443/>

High

Cross-Frame Scripting

Summary:

A Cross-Frame Scripting (XFS) vulnerability can allow an attacker to load the vulnerable application inside an HTML iframe tag on a malicious page. The attacker could use this weakness to devise a Clickjacking attack to conduct phishing, frame sniffing, social engineering or Cross-Site Request Forgery attacks.

Clickjacking

The goal of a Clickjacking attack is to deceive the victim (user) into interacting with UI elements of the attacker's choice on the target web site without their knowledge and then executing privileged functionality on the victim's behalf. To achieve this goal, the attacker must exploit the XFS vulnerability to load the attack target inside an iframe tag, hide it using Cascading Style Sheets (CSS) and overlay the phishing content on the malicious page. By placing the UI elements on the phishing page so they overlap with those on the page targeted in the attack, the attacker can ensure that the victim must interact with the UI elements on the target page not visible to the victim.

WebInspect has detected a page which potentially handles sensitive information using an HTML form with a password input field and is missing XFS protection.

This response while protected by a valid X-Frame-Options does not contain a valid Content-Security-Policy(CSP) frame-ancestors directive. Consider adding CSP as it now replaces X-Frame-Options and is supported in most modern browsers.

Execution:

Create a test page containing an HTML iframe tag whose src attribute is set to <https://bizsmsraz.telekom.rs:443/>. Successful framing of the target page indicates that the application is susceptible to XFS.

Note that WebInspect will report only one instance of this check across each host within the scope of the scan. The other visible pages on the site may, however, be vulnerable to XFS as well and therefore should be protected against it with an appropriate fix.

Implication:

A Cross-Frame Scripting weakness could allow an attacker to embed the vulnerable application inside an iframe. Exploitation of this weakness could result in:

- Hijacking of user events such as keystrokes
- Theft of sensitive information
- Execution of privileged functionality through combination with Cross-Site Request Forgery attacks

Fix:

The Content Security Policy (CSP) frame-ancestors directive obsoletes the X-Frame-Options header. Both provide for a policy-based mitigation technique against cross-frame scripting vulnerabilities. The difference is that while the X-Frame-Options technique only checks against the top-level document's location, the CSP frame-ancestors header checks for conformity from all ancestors.

If both CSP frame-ancestors and X-Frame-Options headers are present and supported, the CSP directive will prevail. WebInspect recommends using both CSP frame-ancestors and X-Frame-Options headers as CSP is not supported by Internet Explorer and many older versions of other browsers.

In addition, developers must also use client-side frame busting JavaScript as a protection against XFS. This will enable users of older browsers that do not support the X-Frame-Options header to also be protected from Clickjacking attacks.

X-Frame-Options

Developers can use this header to instruct the browser about appropriate actions to perform if their site is included inside an iframe. Developers must set the X-Frame-Options header to one of the following permitted values:

- DENY
Deny all attempts to frame the page
- SAMEORIGIN
The page can be framed by another page only if it belongs to the same origin as the page being framed

Content-Security-Policy: frame-ancestors

Developers can use the CSP header with the frame-ancestors directive, which replaces the X-Frame-Options header, to instruct the browser about appropriate actions to perform if their site is included inside an iframe. Developers can set the frame-ancestors attribute to one of the following permitted values:

- 'none'
Equivalent to "DENY" - deny all attempts to frame the page
- 'self'
Equivalent to "SAMEORIGIN" - the page can be framed by another page only if it belongs to the same origin as the page being framed
- <scheme-source>
Developers can also specify a schema such as http: or https: that can frame the page.

Reference:

Busting Frame Busting: a Study of Clickjacking Vulnerabilities on Popular Sites

<https://seclab.stanford.edu/websec/framebusting/framebust.pdf>

OWASP Clickjacking Attack Guide

<https://owasp.org/www-community/attacks/Clickjacking>

OWASP Clickjacking Defense Cheat Sheet

https://cheatsheetseries.owasp.org/cheatsheets/Clickjacking_Defense_Cheat_Sheet.html

Mozilla Developer Network - X-Frame-Options Header

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>

Mozilla Developer Network - CSP frame-ancestors Directive

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy/frame-ancestors>

Microsoft IE Blog - Clickjacking Defenses

<https://learn.microsoft.com/en-us/archive/blogs/ie/ie8-security-part-vii-clickjacking-defenses>

Microsoft IE Internals - Combating Clickjacking with X-Frame-Options

<https://learn.microsoft.com/en-us/archive/blogs/ieinternals/combating-clickjacking-with-x-frame-options>

Content Security Policy Level 2

<https://www.w3.org/TR/CSP2/>

HTTP Header Field X-Frame-Options

<https://datatracker.ietf.org/doc/html/rfc7034>

Attack Request:

```
GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stdid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
```

Attack Response:

```
HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
Set-Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; path=/; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:48:49 GMT
Content-Length: 4713

<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Prijava</title>
  <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

  <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>
```

```

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">

          </ul>

        <ul class="nav navbar-nav navbar-right">

          <li><a href="/" id="loginLink">Prijava</a></li>
          <li style="padding-bottom:11px; padding-top:11px;"></li>
          <li>
            <a href="/Home/SetCulture?culture=en-us">
              <span class="flag-icon flag-icon-gb"></span>
            </a>
          </li>
        </ul>

      </div>
    </div>
    <div class="container body-content">

      <h2>Prijava</h2>
      <div class="row">
        <div class="col-md-12">
          <section id="loginForm">
            <form action="/" class="form-horizontal" method="post" role="form"><input name="__RequestVerificationToken"
            type="hidden" value="QIQ8mRUTN0iee6LdzuqQ6IszC6bfJO4waM0QZzJhxle-
            QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZCI39FMpTfTi5TmPXQjCKNKZ881" />          <hr />
            <div class="form-group">
              <label class="col-md-2 control-label" for="Username">Korisničko ime</label>
              <div class="col-md-10">
                <input class="form-control" data-val="true" data-val-required="Korisničko ime je obavezno polje"
                id="Username" name="Username" type="text" value="" />
                <span class="field-validation-valid text-danger" data-valmsg-for="Username" data-valmsg-
                replace="true"></span>
              </div>
            </div>
            <div class="form-group">
              <label class="col-md-2 control-label" for="Password">Lozinka</label>
              <div class="col-md-10">
                <input class="form-control" data-val="true" data-val-required="Lozinka je obavezno polje" id="Password"
                name="Password" type="password" />
                <span class="field-validation-valid text-danger" data-valmsg-for="Password" data-valmsg-
                replace="true"></span>
              </div>
            </div>
            <div class="form-group">
              <div class="checkbox">
                <input data-val="true" data-val-required="The Zapamti me? field is required." id="RememberMe"
                name="RememberMe" type="checkbox" value="true" /><input name="RememberMe" type="hidden" value="false" />
                <label for="RememberMe">Zapamti me?</label>
              </div>
            </div>
            <div class="form-group">
              <div class="col-md-offset-2 col-md-10">
                <input type="submit" value="Prijava" class="btn btn-default" />
              </div>
            </div>
          </section>
        </div>
      </div>
    </div>
  </div>
  ...TRUNCATED...

```

File Names: ● <https://bizsmsraz.telekom.rs:443/>

High

Web Server Misconfiguration: Unprotected Directory

Summary:

WebInspect has detected a backup directory with (copy) suffix on the target server. It might contain sensitive artifacts such as source code and design documents relevant to the site. Based on the directory contents, the attacker can gain sensitive information about the site architecture, database and network access credential details, encryption keys, and so forth from these files. The attacker may use information obtained to create precise targeted attacks, which may not otherwise be feasible, against the application.

Execution:

Browse to [https://bizsmsraz.telekom.rs:443/api/home/getgroups/adm%20\(copy\)/](https://bizsmsraz.telekom.rs:443/api/home/getgroups/adm%20(copy)/) and inspect the content. Response should be a return with HTTP status code 200 and should not match target site's file not found response.

Implication:

An attacker may use the information obtained from the backup directory contents to craft a precise targeted attack against the web application. Such attacks can include, but are not limited to, SQL injection, remote file system access to overwrite or inject malware, and database manipulation.

Fix:

Prohibit storage of backup directories on webroot. Further QA can include test cases to look for the presence of backup directories in the webroot to ensure none are left in publicly accessible folders of the web application.

Reference:

[OWASP - Review Old, Backup and Unreferenced Files for Sensitive Information \(OTG-CONFIG-004\)](#)
[CWE - 200 Information Exposure](#)

Attack Request:

```
GET /api/home/getgroups/adm%20(copy)/ HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/api/home/getgroups/adm/
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: bizsmsraz.telekom.rs
Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
Category="Audit.Attack";SID="D74E5DC9C5DDAAA34CC1F8577350B3C5";PSID="11598E204B1E9B049CB8F14E820227AC";SessionType="AuditAttack";CrawlType="None";AttackType="Search";OriginatingEngineID="6798a0e1-0603-4a14-83fb-ad85afa73fa8";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamSubIndex="0";CheckId="11485";Engine="Directory+Extension+Addition";SmartMode="4";tht="40";
X-RequestManager-Memo: stid="1193";stmi="0";sc="1";rid="26d33352";
X-Request-Memo: rid="892192eb";sc="1";thid="758";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=S7VCzMBLsJpZfD1TEgrLigqmUG9bBZe3Oxu0PRAVTmivewFPyei8pgt5ionfkj3_PpkJXIIlSRMpB-SiewM0NH41Krb1_pcrQ8hCy9t_yAsY1;.AspNet.ApplicationCookie=_EI4YC_JIE1jRPczhfXZ4fvlC4rYaUVDJ8BFklcMKDpKGs99ewlMhH77C3eZ2ymMTwMQXkEFmW7lsKVmDUQ_W6ZSqYtJo0FgQX13s5CIJn8S1GI_x7budyFxpRBNrGosTMnOuuRbHpnfPXLhqROtdOMYXhW_34jwkV4qw7lKknXCZ1uYpq0gnIydHDdCDEIAUePYIRsmzMOI0laH_OY1_6Xg2U4DQtRBLq-NBhDOAB609JTy1igmhMB5OZDAVqbQeJrScfYdH6Bf0Byqm_sutGP5VrRrWYOMG8yMSVh3FhF5HGxUyW0WLRf89Z6MC8nRirS_F7JZ8uyOwZ4BzeR7z5VaQ-5UGUaQvCS7U-P1vGzvCtQrg2jLQoaFbblAxyhHKcRaCBTtPFM1Zku3vMtG3y2H3PO3c8ptyJ-TqrOxr-SWyKFSUUnIkx8TSq7HDdq_ZiFhpMwrBR5dINnxZVV1y93M_5ImS1WWQnjGqzH5NTHVLFxA3QrEblQ5k0gWATOoEuxJKmCTMQyerS0eaQw;_culture=sr
```

Attack Response:

```
HTTP/1.1 200 OK
Cache-Control: no-cache
Pragma: no-cache
Co...TRUNCATED...
```

File Names: ● [https://bizsmsraz.telekom.rs:443/api/home/getgroups/adm%20\(copy\)/](https://bizsmsraz.telekom.rs:443/api/home/getgroups/adm%20(copy)/)
● [https://bizsmsraz.telekom.rs:443/api/home/getgroups/.git%20\(copy\)/](https://bizsmsraz.telekom.rs:443/api/home/getgroups/.git%20(copy)/)

Medium

Cookie Security: Cookie not Sent Over SSL

Summary:

This policy states that any area of the website or web application that contains sensitive information or access to privileged functionality such as remote site administration requires that all cookies are sent via SSL during an SSL session. The URL: <https://bizsmsraz.telekom.rs:443/> has failed this policy. If a cookie is marked with the "secure" attribute, it will only be transmitted if the communications channel with the host is a secure one. Currently this means that secure cookies will only be sent to HTTPS (HTTP over SSL) servers. If secure is not specified, a cookie is considered safe to be sent in the clear over unsecured channels.

Fix:

Set the `Secure` attribute on the Cookie so that the Cookie is not sent over an unencrypted HTTP request.

Require SSL for an Authentication Cookie (IIS 7):

[http://technet.microsoft.com/en-us/library/cc771633\(WS.10\).aspx](http://technet.microsoft.com/en-us/library/cc771633(WS.10).aspx)

AnonymousIdentificationSection Class [IIS 7]:

<http://msdn.microsoft.com/en-us/library/ms689482.aspx>

Use the following links to remediate this issue on an Apache server:

<http://search.cpan.org/~jkrasnoo/ApacheCookieEncrypted-0.03/Encrypted.pm>

<http://hc.apache.org/httpclient-3.x/apidocs/org/apache/commons/httpclient/class-use/Cookie.html>

Set-Cookie - HTTP MDN (mozilla.org)

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie#secure>

Secure Cookie Attribute OWASP Foundation

<https://owasp.org/www-community/controls/SecureCookieAttribute>

Reference:

General Information:

[The Unofficial Cookie FAQ](#)

Attack Request:

```
GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
```

Attack Response:

```
HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
Set-Cookie:
RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCViz0EE1kyKSLY_2XNrb22nFkr3-9cTNxFeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; path=/; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security...TRUNCATED...
```

Summary:

Cookies are small bits of data that are sent by the web application but stored locally in the browser. This lets the application use the cookie to pass information between pages and store variable information. The web application controls what information is stored in a cookie and how it is used. Typical types of information stored in cookies are session Identifiers, personalization and customization information, and in rare cases even usernames to enable automated logins. There are two different types of cookies: *session cookies* and *persistent cookies*. Session cookies only live in the browser's memory, and are not stored anywhere. Persistent cookies, however, are stored on the browser's hard drive. This can cause security and privacy issues depending on the information stored in the cookie and how it is accessed.

Execution:

All cookies are set by the server via the Set-Cookie HTTP Header. A browser knows to store that cookie as a persistent cookie when it finds the keyword 'Expires=' followed by a date in the future. If there is no 'Expires=' tag, or if the specified date has already passed, then the browser will keep the cookie in memory only as a session cookie.

To view the persistent cookie set on this page, view the **HTTP response** and examine the Set-Cookie header. You should see the 'Expires=' tag with a future date specified.

Implication:

Persistent cookies are stored on the browsing clients hard drive even when that client is no longer browsing the Web site that set the client. Depending on what information is stored in the cookie, this could lead to security and privacy violations. The Office of Management and Budget has decreed that no federal websites shall use persistent cookies except in very specific situations.

Fix:

From a coding perspective, the only distinction between a session cookie and a persistent cookie is the 'Expires=' tag that specifies when a persistent cookie should expire. If a cookie has no 'Expires=' tag, then it is automatically interpreted as a session cookie. Removing the expiration date from the code that sets the cookie will change it to a session cookie.

Reference:

[Cookie Security: Persistent Cookie](#)

Attack Request:

```
GET /Home/SetCulture?culture=en-us HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: bizsmsraz.telekom.rs
Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
Category="Crawl";SID="F650BF16A753C585B290A85D1E497073";PSID="3631635452D193C2F6DB1B63BD7CA0F0";SessionType="Crawl";CrawlType="HTML";AttackType="None";OriginatingEngineID="00000000-0000-0000-0000-000000000000";AttributeName="href";Format="Relative";LinkKind="HyperLink";Locations="HtmlNode";Source="ScriptExecution";tht="31";
X-RequestManager-Memo: stid="1113";stmi="0";sc="1";rid="dad9fb52";
X-Request-Memo: rid="0d66ba0c";sc="1";thid="595";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1;.AspNet.ApplicationCookie=tk1Tj-x-PoW1x93e5uD2dC4TV2UwYVhp1eWCGbzcEWZGCRiet3nCWlwLeHyK2fjxuB6FMe-PUku7qTco70stH5utNPSIrS5TmFcbcbODY8w3wuhVP8QX1A0itUqchYKK0j_z5HVRHqKF4CEq3mZXpTOOIq8vvz1ctpO1HBzn-iXeOd4EmSrR7XTog-Xx_FfmAXcxKszNR23k0dhTHu3GhznYpiwFRVazFso1QgGQk34dHzO-AvxGKoKD3CEeNqOos4NAQB8wb4ValRtSP3RoypoXEnUSZsFXekiCoThknY7XdaT-oAs0T-jgbEFtnYREHQScJ6jpFfJ1a3nRuEcUS58eSa_fu303PBiqQFzsW7kipigde6iF38gtJas7TRf7GMO8e_TVjyxkFK-Lg21sM1XzfqZiyQaqdJLAVDeo0ysg3vvvVq_G2LP9INoS4RojBaSRobXCzeA3jGYnEkunFZh1TXWMldQTL2trWasuNep8Pj1TWG2gF9AcumKjbm
```

Attack Response:

```
HTTP/1.1 302 Found
Cache-Control: private
Content-Type: text/html; charset=utf-8
Location: /Home/Index
Server: Microsoft-IIS/10.0
```

X-AspNetMvc-Version: 5.2
X-AspNet-Version: 4.0.30319
Set-Cookie: _culture=en-us; expires=**Fri, 16-Apr-2027 06:49:24 GMT**; path=/
X-Powered-By: ASP.NET
Strict-Transport-...TRUNCATED...

File Names: ● <https://bizsmsraz.telekom.rs:443/Home/SetCulture?culture=en-us>

Medium

Flash Bad Practices: Insecure Embedded SWF Settings

Summary:

An HTML page has been found to embed a SWF file with unsafe permissions. The AllowScriptAccess setting determines a SWF's ability to communicate with the browser using commands like fscommand() and ExternalInterface(). By default a SWF file and an HTML page loading the SWF can communicate only if both are located within the same domain. Setting the value of the AllowScriptAccess parameter in the PARAM or EMBED tag in an HTML page to "always" will allow a SWF file to communicate to an HTML page even if they are from different domains. This can result in attacks such as script injection, cross-domain privilege escalation, etc.

Implication:

A malicious SWF file with unrestricted access to the hosting HTML page can be used to steal sensitive information such as cookies or execute malicious script code on the page.

Fix:

Remove the AllowScriptAccess parameter from the PARAM and EMBED HTML tags.

Reference:

Creating more secure SWF web applications

http://www.adobe.com/devnet/flashplayer/articles/secure_swf_apps_04.html

OWASP Flash Security Project

http://www.owasp.org/index.php/Category:OWASP_Flash_Security_Project

Flash attack vectors (and worms)

<http://isc.sans.org/diary.html?storyid=7015>

Attack Request:

GET /bundles/jquery-datatables-buttons?v=2BPkwBkFU1d_gjeyBUCwuNuxtpD7BYPM358Ff4TbiDw1 HTTP/1.1
Referer: <https://bizsmsraz.telekom.rs/Home/SentSMSReport>
Host: bizsmsraz.telekom.rs
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Sec-Fetch-Dest: script
Sec-Fetch-Mode: no-cors
Sec-Fetch-Site: same-origin
Pragma: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
ScriptEngine="Gecko";Category="Crawl";SID="D5B3932C96F7AAD14140197A48371A8E";PSID="6C1A8B9065D844A3C82CDD
E7E06EABF5";SessionType="Crawl";CrawlType="ScriptInclude";AttackType="None";OriginatingEngineID="00000000-0000-
0000-0000-000000000000";tht="21";
X-RequestManager-Memo: stid="1113";stmi="0";sc="1";rid="9b4ff916";
X-Request-Memo: rid="d17c449d";sc="1";thid="796";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=vdo9iRP2ld
89LL4rG2ZjdsCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-
lc8mUQUmI6XbgvPvNk1;.AspNet.ApplicationCookie=tk1Tj-x-
PoW1x93e5uD2dC4TV2UwYVhp1eWCGbzcEWZGCIrieT3nCWlWLeHyK2fjxuB6FMe-
PUku7qTco70stH5utNPSIrS5TmFbcbbODY8w3wuhVP8QX1A0itUqchYKK0j_z5HVRHqKF4CEq3mZXpTOOIq8vzv1ctpO1HBzn-
iXeOd4EmSrR7XTog-Xx_FfmAXcxKszNR23k0dhTHu3GhznYpiwFRVazFso1QgGQk4dHzO-
AvxGKoKD3CEeNqOos4NAQB8wb4ValRtSP3RoypoXEnUSZsFXekiCoThknY7XdaT-oAs0T-
jgbEFtnYREHQScJ6jpFfJ1a3nRuEcUS58eSa_fu303PBiQOFzsw7kipigde6iF38gtJas7TRf7GMO8e_TVjyxkfK-
Lg21sM1XzfQZiyQaqdJLAvDEo0ysg3vvvVq_G2LP9iNoS4RojBalSRobXCzeA3jGYnEkunFZh1TXWMIldQL2trWASuNep8Pj1TWG2gF
9AcumKjbM;_culture=en-us

Attack Response:

HTTP/1.1 200 OK
Cache-Control: public
Content-Type: text/javascript; charset=utf-8
Expires: Fri, 16 Apr 2027 06:49:34 GMT
Last-Modified: Thu, 16 Apr 2026 06:49:34 GMT
Vary: User-Agent,Accept-Encoding
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:49:33 GMT
Content-Length: 1124288

```
...TRUNCATED...ame="wmode" value="transparent"/><\object>');i+=<embed id="+this.movieId+"  
src="+u.moviePath+" loop="false" menu="false" quality="best" bgcolor="#ffffff" width="+n+" height="+t+"  
name="+this.movieId+" align="middle" allowScriptAccess="always" allowFullScreen="false" type="application/x-  
shock...TRUNCATED...
```

File Names:

- https://bizsmsraz.telekom.rs:443/bundles/jquery-datatables-buttons?v=2BPkwBkFU1d_gjeyBUcwuNuxtpD7BYP

Medium

Cross-Frame Scripting

Summary:

A Cross-Frame Scripting (XFS) vulnerability can allow an attacker to load the vulnerable application inside an HTML iframe tag on a malicious page. The attacker could use this weakness to devise a Clickjacking attack to conduct phishing, frame sniffing, social engineering or Cross-Site Request Forgery attacks.

Clickjacking

The goal of a Clickjacking attack is to deceive the victim (user) into interacting with UI elements of the attacker's choice on the target web site without their knowledge and then executing privileged functionality on the victim's behalf. To achieve this goal, the attacker must exploit the XFS vulnerability to load the attack target inside an iframe tag, hide it using Cascading Style Sheets (CSS) and overlay the phishing content on the malicious page. By placing the UI elements on the phishing page so they overlap with those on the page targeted in the attack, the attacker can ensure that the victim must interact with the UI elements on the target page not visible to the victim.

WebInspect has detected a response containing one or more forms that accept user input but is missing XFS protection.

This response while protected by a valid X-Frame-Options does not contain a valid Content-Security-Policy(CSP) frame-ancestors directive. Consider adding CSP as it now replaces X-Frame-Options and is supported in most modern browsers.

Execution:

Create a test page containing an HTML iframe tag whose src attribute is set to <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/206000>. Successful framing of the target page indicates that the application is susceptible to XFS.

Note that WebInspect will report only one instance of this check across each host within the scope of the scan. The other visible pages on the site may, however, be vulnerable to XFS as well and therefore should be protected against it with an appropriate fix.

Implication:

A Cross-Frame Scripting weakness could allow an attacker to embed the vulnerable application inside an iframe. Exploitation of this weakness could result in:

- Hijacking of user events such as keystrokes
- Theft of sensitive information
- Execution of privileged functionality through combination with Cross-Site Request Forgery attacks

Fix:

The Content Security Policy (CSP) frame-ancestors directive obsoletes the X-Frame-Options header. Both provide for a policy-based mitigation technique against cross-frame scripting vulnerabilities. The difference is that while the X-Frame-Options technique only checks against the top-level document's location, the CSP frame-ancestors header checks for conformity from all ancestors.

If both CSP frame-ancestors and X-Frame-Options headers are present and supported, the CSP directive will prevail. WebInspect recommends using both CSP frame-ancestors and X-Frame-Options headers as CSP is not supported by Internet Explorer and many older versions of other browsers.

In addition, developers must also use client-side frame busting JavaScript as a protection against XFS. This will enable users

of older browsers that do not support the X-Frame-Options header to also be protected from Clickjacking attacks.

X-Frame-Options

Developers can use this header to instruct the browser about appropriate actions to perform if their site is included inside an iframe. Developers must set the X-Frame-Options header to one of the following permitted values:

- DENY
Deny all attempts to frame the page
- SAMEORIGIN
The page can be framed by another page only if it belongs to the same origin as the page being framed

Content-Security-Policy: frame-ancestors

Developers can use the CSP header with the frame-ancestors directive, which replaces the X-Frame-Options header, to instruct the browser about appropriate actions to perform if their site is included inside an iframe. Developers can set the frame-ancestors attribute to one of the following permitted values:

- 'none'
Equivalent to "DENY" - deny all attempts to frame the page
- 'self'
Equivalent to "SAMEORIGIN" - the page can be framed by another page only if it belongs to the same origin as the page being framed
- <scheme-source>
Developers can also specify a schema such as http: or https: that can frame the page.

Reference:

Busting Frame Busting: a Study of Clickjacking Vulnerabilities on Popular Sites

<https://seclab.stanford.edu/websec/framebusting/framebust.pdf>

OWASP Clickjacking Attack Guide

<https://owasp.org/www-community/attacks/Clickjacking>

OWASP Clickjacking Defense Cheat Sheet

https://cheatsheetseries.owasp.org/cheatsheets/Clickjacking_Defense_Cheat_Sheet.html

Mozilla Developer Network - X-Frame-Options Header

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>

Mozilla Developer Network - CSP frame-ancestors Directive

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy/frame-ancestors>

Microsoft IE Blog - Clickjacking Defenses

<https://learn.microsoft.com/en-us/archive/blogs/ie/ie8-security-part-vii-clickjacking-defenses>

Microsoft IE Internals - Combating Clickjacking with X-Frame-Options

<https://learn.microsoft.com/en-us/archive/blogs/ieinternals/combating-clickjacking-with-x-frame-options>

Content Security Policy Level 2

<https://www.w3.org/TR/CSP2/>

HTTP Header Field X-Frame-Options

<https://datatracker.ietf.org/doc/html/rfc7034>

Attack Request:

GET /Group/EditListNumber/206000 HTTP/1.1

Referer: https://bizsmsraz.telekom.rs/api/Group/GetListNumbers?_=1776322173178

Accept: */*

Pragma: no-cache

Accept-Encoding: gzip, deflate

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0

Host: bizsmsraz.telekom.rs

Connection: Keep-Alive

X-WIPP: AscVersion=25.4.0.57

X-Scan-Memo:

Category="Crawl";SID="537838DB70EC0CCF12EA38B806D696CF";PSID="651FDC50B737952659F0FFB61AD6EBC8";SessionType="Crawl";CrawlType="HTML";AttackType="None";OriginatingEngineID="00000000-0000-0000-0000-000000000000";Format="Relative";LinkKind="HyperLink";Locations="StructuredContent";Source="StaticParser";SubLocation="JSON";tht="31";

X-RequestManager-Memo: stid="1113";stmi="0";sc="1";rid="5d8cb6e2";

X-Request-Memo: rid="eb00b443";sc="1";thid="565";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=kmHpv75c
IQIEz_bDwEiw7S8xYOFXSDy346tOJyowYkOvZcZilQCfMprww28VdL773VjUY-
xhKxhP_qWjbpjctwXcvCr7QLtGtlDnobeZ0HE1;.AspNet.ApplicationCookie=wY63RIHJQdyKFzBBoC3G0dOCgxuKMwRgncHeXv16
Roe1rE_QnvV0XoOamUUKEQD5NR153EJEUraSPARenp0qYymPzb-N7NNQxJZO0-LBLrikZCIKq-P6wYN_-
MNdwpTaTr_Hv7L8bXTLtB1hpfF5FqgYtlgAGo7krIqt4gCfvjcm0JrallyumAa8IKb6WD0-UE95_eCQjurrDWOQGjBa-
I7TNhWGDtzizjkGyyTxHjrUDnTUaw2BZZS5rK_8CwwmtwV92sw8zhXGge35T5Jivru0OrMift3OwPz5bT_9UjjAcoNH3mwkRJBAXMa
uc2jrRe-N-sz8bs6-og2bWWTUZfg-qqegYfflKt2V3YmbiIYMSDUfNCqxFPxnJ3Fpifuh5FR5Bv1OQ7WDPCTRxYFVsaCFj0fm4-
kJPhwOvu3GtvOSi6KysGqGXhN1aV4k4bgIXq3VvjVA4ZV2r8IW7sJRrFa9fSAFrFZeqlMuLpJc-
5AGsyUARG0ILOIPGP7oRT8Jv;_culture=en-us

Attack Response:

HTTP/1.1 200 OK
Cache-Control: private, s-maxage=0
Content-Type: text/html; charset=utf-8
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:51:16 GMT
Content-Length: 6582

```
<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Edit number</title>
  <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

  <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">
          <li><a href="/Home/SendSMS">Send SMS</a></li>
          <li><a href="/Group/Index">Groups</a></li>
          <li><a href="/Group/ListNumbers">Numbers</a></li>
          <li><a href="/Home/SentSmsReport">Monthly report</a></li>
          <li><a href="/Home/SentSMSJobReport">Sent SMS report</a></li>

        </ul>

        <form action="/Account/LogOff" class="navbar-right" id="logoutForm" method="post"><input
name="__RequestVerificationToken" type="hidden"
value="W35Q2ISqifHQsQb0_WEH3CxYoQYjrx_ENqaYw7N97ZCe49IUs22qFpseAT05BhwxIG_I0aBIbetksNv7mrPC_kvpX1I_ATZ2
Cz-1rPIKhd3k3K3ACmmV67QtOfiHoRVCRvZu75YAaiICIIsbO5a6f9A2" />
          <ul class="nav navbar-nav navbar-right">
            <li class="dropdown">
              <a href="#" class="dropdown-toggle" data-toggle="dropdown" role="button" aria-haspopup="true" aria-
expanded="false"> Welcome marijamar <span class="caret"></span></a>
              <ul class="dropdown-menu">
                <li><a href="/Manage/ChangePassword" title="Change password">Change password</a></li>

                <li><a href="/Home/DownloadManual" target="_blank" title="User Manual">User Manual</a></li>

              </ul>
            </li>
          </ul>
        </div>
      </div>
    </div>
  </div>
  <li role="separator" class="divider"></li>
```

```

        <li><a href="javascript:document.getElementById('logoutForm').submit()">Log out</a></li>
    </ul>
</li>

</ul>
</form>
</div>
</div>
</div>
<div class="container body-content">

<h2>Edit number</h2>

<form action="/Group/EditListNumber/206000" method="post"><input name="__RequestVerificationToken" type="hidden"
value="04LLWwGwHdiPtXQzhIW-b_KRAJmT9EvN-qEKuzm_TgG0yHzO-
cH7ppP6ErFk6Iy7IF2d99qhi2EQHj2wFcjMMAuYF5ql7cE85PbB2PMYmSNYPqkbZJcnWt3GL7tBULI-P-
PvXjBZkN0mWzdC_anFrw2" /> <div class="form-horizontal">
    <hr />

    <input data-val="true" data-val-number="The field NumberID must be a number." data-val-required="The NumberID
field is required." id="NumberID" name="NumberID" type="hidden" value="206000" />

    <div class="form-group">
        <label class="control-label col-md-2" for="Number">Number</label>
        <div class="col-md-10">
            <div class="form-control-static">
                0648736425
            </div>
        </div>
    </div>

    <div class="form-group">
        <label class="control-label col-md-2" for="Name">Name</label>
        <div class="col-md-10">
            <input class="form-control text-box single-line" data-val="true" data-val-length="The Name must be at least 3
characters long." data-val-length-max="30" data-val-length-min="3" data-val-required="Name is required" id="Name"
name="Name" type="text" value="SEKRETARICE" />
            <span>
...TRUNCATED...

```

File Names: ● <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/206000>

Medium

Cross-Frame Scripting

Summary:

A Cross-Frame Scripting (XFS) vulnerability can allow an attacker to load the vulnerable application inside an HTML iframe tag on a malicious page. The attacker may use this weakness to devise a Clickjacking attack to conduct phishing, frame sniffing, social engineering or cross-site request forgery attacks.

The X-Frame-Options header and the Content Security Policy: frame-ancestors directive header are the recommended way to protect against the Cross-Frame Scripting vulnerability. Using these headers prevents or controls the domains that can embed a target page within an iframe. Misconfiguration of either of these headers could, however, still leave an application exposed to the above attacks.

Multiple X-Frame-Options headers were observed in this response. Multiple headers or multiple values in a single header could be mishandled by various browsers. Hence it is advisable to send a single X-Frame-Options header with a single value.

Execution:

Observe the X-Frame-Options and the Content Security Policy frame-ancestors headers in the raw HTTP responses and try to frame the page in accordance with what is desired vs what is configured.

Implication:

Various desktop and mobile browsers incorrectly handle duplicate X-Frame-Options headers and multiple value assignments in a single header. This can allow an attacker to completely bypass the security control.

It is recommended to provide a white-list of domains allowed to embed the target page in the allow-from directive of the X-Frame-Options header. The allow-from directive also accepts a wildcard (*) character. Such a configuration nullifies the effectiveness of the header and should be avoided.

The X-Frame-Options directive is supported in a meta tag by a few browsers. However, various browsers can misinterpret the use of both the header and meta tag. Therefore, usage of the meta tag for X-Frame-Options is not recommended.

Fix:

- Use only a single instance of the X-Frame-Options header in a given response.
- Do not use a wildcard should along with the allow-from or directive.
- If Content Security Policy frame-ancestors directive is configured with a content source, then it must be followed by a colon (:). (for example http: or https:).
- Avoid using a meta tag to protect against Cross-Frame Scripting.

The recommended protection from Cross-Frame Scripting is a properly configured X-Frame-Options and Content-Security-Policy header with frame-ancestors attribute along with JavaScript framebusting code.

Reference:**Frame Busting:**

[Busting Frame Busting: A Study of Clickjacking Vulnerabilities on Popular Sites](#)
[OWASP: Busting Frame Busting](#)

OWASP:

[Clickjacking](#)

Content-Security-Policy (CSP)

[CSP: frame-ancestors](#)

Specification:

[Content Security Policy Level 2](#)
[X-Frame-Options IETF Draft](#)

Server Configuration:

[IIS](#)
[Apache, nginx](#)

HP 2012 Cyber Security Report

[The X-Frame-Options header - a failure to launch](#)

Attack Request:

```
GET /Account/VerifyPhoneNumber?phoneNumber=0641839461&provider=Phone%20Code HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: https://bizsmsraz.telekom.rs/
Connection: keep-alive
Pragma: no-cache
Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; .AspNet.TwoFactorCookie=mQcyi1JygR6d2060SIQr-mZVWLLIUpxKLjK-aiexPayJLlJraKV2krl5U39RA9mnwSk2y7bkSGE0y6B5BGyP7Bk7FtLuMpaHTZe9uYts7EuB_ND0PnkmVykrBRHXCe358fXqPN9_saiu-TZLTU3-MSQ_0DxrG5NVZn1SYShNow3x-haTJs3c2-WOSTngsDLJiz59t4rQUADGYabdwTqu5pNxPIUuwCLP-dumObzeUdrSdRnr6IC7v5ElrWhpFIRIVxo5VNsY-N8PFI88x3Xfq-kVWw-jBLPOxpX8ptDDVr05iX4zdFs_9wVEwPSE2cmV5CYZFlogiEavda-gimQ;CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="019ca71d";thid="640";
```

Attack Response:

```
HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:51 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:51 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
```

File Names: ● <https://bizsmsraz.telekom.rs:443/Account/VerifyPhoneNumber?phoneNumber=0641839461&provider=Phone%20C>

Medium

Privacy Violation: Inconsistent Feedback

Summary:

When entering an invalid username or password during a login, an application may provide meaningful feedback through a response discrepancy. For the potential attacker, this discrepancy increases the chances of a successful brute force attack against the site's authentication.

Execution:

Try logging into the application twice, once with an incorrect username and another time with an incorrect password. A generic error message for both attempts indicates a secure application. On the other hand, if there is a difference in the error messages, the application may be providing information that could be used in a brute-force attack.

Implication:

Consider an application that takes an email address/username and a password. If the application provides different error messages for a non-existent email address and an incorrect password, it will enable an attacker to submit multiple email addresses and learn about the ones that are actually registered to the application. Being able to enumerate users in an application may enable an attacker to perform a more efficient brute force attack.

Fix:

Applications should not indicate specifically whether a user account or password was incorrect, rather a very generic login failure message should be used. For example, during a new user registration or forgotten password function, no meaningful message should be returned to the requestor, rather an email should be sent to the account in question with details of how to reset a forgotten password or reclaim an account.

Reference:

OWASP Guide to Authentication

https://www.owasp.org/index.php/Guide_to_Authentication

Username Enumeration Vulnerabilities

<http://www.gnucitizen.org/blog/username-enumeration-vulnerabilities>

Attack Request:

```
POST / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: https://bizsmsraz.telekom.rs/
Content-Type: application/x-www-form-urlencoded
Content-Length: 197
Origin: https://bizsmsraz.telekom.rs
Connection: keep-alive
Pragma: no-cache
Cookie: __RequestVerificationToken=H4MZxgJ9RzB9-nQZxFaiUqIzNI8seFdLMWBZds69OUoZWJLX6mO96qB2PjMhZPAL4K9Y2UCS6kVY31vF-KMNCQ6oKhZWaFZq8joUBPGEdoY1;CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stdid="1253";stmi="0";Category="EventMacro.DirectMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="a4b39b0f";thid="864";

...TRUNCATED...TzhCwoWEowL6O37t95WsP30qVydfiMVS7D_bCk1&Username=spiuser
&Password=Marjamar%21%2123&RememberMe=false
```

Attack Response:

```
HTTP/1.1 200 OK
Cache-Control: private
Content-Type: text/html; charset=utf-8
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
```

X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:56:28 GMT
Content-Length: 4834

```
...TRUNCATED...ar-collapse collapse">  
    <ul class="nav navbar-nav">  
  
    </ul>  
...TRUNCATED...
```

File Names: ● <https://bizsmsraz.telekom.rs:443/>

Low

Poor Error Handling: Unhandled Exception

Summary:

A minor vulnerability has been discovered within your web application due to the the presence of a fully qualified path name to the root of your system. This most often occurs in context of an error being produced by the web application. Fully qualified server path names allow an attacker to know the file system structure of the web server, which is a baseline for many other types of attacks to be successful. Recommendations include adopting a consistent error handling scheme and mechanism that prevents fully qualified path names from being displayed.

Execution:

To verify the issue, click the 'HTTP Response' button on the properties view and review the highlighted areas to determine the Unix path found.

Fix:

For Development:

Don't display fully qualified pathnames as part of error or informational messages. At the least, fully qualified pathnames can provide an attacker with important information about the architecture of web application.

For Security Operations:

The following recommendations will help to ensure that a potential attacker is not deriving valuable information from any error message that is presented.

- **Uniform Error Codes:** Ensure that you are not inadvertently supplying information to an attacker via the use of inconsistent or "conflicting" error messages. For instance, don't reveal unintended information by utilizing error messages such as Access Denied, which will also let an attacker know that the file he seeks actually exists. Have consistent terminology for files and folders that do exist, do not exist, and which have read access denied.
- **Informational Error Messages:** Ensure that error messages do not reveal too much information. Complete or partial paths, variable and file names, row and column names in tables, and specific database errors should never be revealed to the end user. Remember, an attacker will gather as much information as possible, and then add pieces of seemingly innocuous information together to craft a method of attack.
- **Proper Error Handling:** Utilize generic error pages and error handling logic to inform end users of potential problems. Do not provide system information or other data that could be utilized by an attacker when orchestrating an attack.

For QA:

In reality, simple testing can usually determine how your web application will react to different input errors. More expansive testing must be conducted to cause internal errors to gauge the reaction of the site.

The best course of action for QA associates to take is to ensure that the error handling scheme is consistent. Do you receive a different type of error for a file that does not exist as opposed to a file that does? Are phrases like "Permission Denied" utilized which could reveal the existence of a file to an attacker? It is often a seemingly innocuous piece of information that provides an attacker with the means to discover something else which he can then utilize when conducting an attack.

Attack Request:

GET /bundles/jquery-datatables-buttons HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/bundles/jquery-datatables-buttons?
v=2BPkwBkFU1d_gjeYBUcwuNuxtpD7BYPM358Ff4TbiDw1
Accept: */*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: bizsmsraz.telekom.rs
Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
Category="Audit.Attack";SID="C6B617E2C04D6F46140274BF45E962DF";PSID="D5B3932C96F7AAD14140197A48371A8E";Se
ssionType="PathTruncation";CrawlType="None";AttackType="None";OriginatingEngineID="398bfe9e-1b77-4458-9691-
603eea06e341";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamSubIndex="0";CheckId="0";En
gine="Path+Truncation";SmartMode="4";tht="11";
X-RequestManager-Memo: stid="1181";stmi="0";sc="1";rid="da4dfa73";
X-Request-Memo: rid="b13e7630";sc="1";thid="753";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=hjHXO6KW
PH-O8PhVRO2wsnIRIvh6fUz8mEnnPBQX7ZVSds6QhU_0oHiH5kYYJg36TCw3oAIUKUYwtFTv5ECE-
4ZzCB1kKspAi0grE6_X4c1;.AspNet.ApplicationCookie=tA7i9nY5IB653Uw5oN1jFwOAD_SdiKdL_gd4V3D1tpAy9Sqb-
Tr2g5H6B_twD2YJt9zBX8YsyLuO-
m0YZSk2tWwNMQxhDzbY3cvMMEeOFbPv7U9QBPOQ_FTWTWWe38eLt18GcQI6b1Cyyki40ILHXcDrfF0bqloUKrw8xLyuGJuFoaRP
WnYBmDdrDwF_XTr3xArwtGI1IxFKAEFSRCm6_Wb5XShYJAi2OIWkvL4ad_oh_I0csBGaKImRU8RbCpnLX5wkHIOGDtNIUaXhuT_
oP32bPzCEL8vzbgbXvnuMu5pi8BaJVPb_kJuKNfCpG1M8nvFzz8jAQ05IWgEXkycu6rFuOJ0hkKphGy2vq01MxFTkSRJ0rrtUVp2f-
im1RgmgiUUmqhb38wpDwVPyMyWCu9lggAK1IAP8NLXNwymC0wyO0q5AXmByd7wUliieiIIwOjVr2MODvrjk0yn7NhtZi8LMDoiBbt
kcXmam6mX3iMSa84cq9aHvANQ4qvJtO5PB;_culture=sr

Attack Response:

HTTP/1.1 200 OK
Cache-Control: public
Content-Type: text/javascript; charset=utf-8
Expires: Fri, 16 Apr 2027 07:14:31 GMT
Last-Modified: Thu, 16 Apr 2026 07:14:31 GMT
Vary: User-Agent,Accept-Encoding
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 07:14:31 GMT
Content-Length: 1023586

...TRUNCATED...9//vAPn/7wD6/+8A/f/vAP//7wEE/+8BNf/vAUT/7wFJ/+8Cd//vAr//7wLB/
+8Cw//vAsT/7wNt/+8Dkv/vA5T/7wOX//ADmf/vA57/7wOu/+8...TRUNCATED...

- File Names:
- https://bizsmsraz.telekom.rs:443/bundles/jquery-datatables-buttons
 - https://bizsmsraz.telekom.rs:443/bundles/custom?v=D92H56rQB1a-SyJSzx3-vvqKEbrjLB59At3fs-ZuS3g1

Low

Web Server Misconfiguration: Unprotected Directory

Summary:

Directory Enumeration vulnerabilities were discovered within your web application. Risks associated with an attacker discovering a directory on your application server depend upon what type of directory is discovered, and what types of files are contained within it. The primary threat, other than accessing files containing sensitive information, is that an attacker can utilize the information discovered in that directory to perform other types of attacks. Recommendations include restricting access to important directories or files by adopting a "need to know" requirement for both the document and server root, and turning off features such as Automatic Directory Listings that provide information that could be utilized by an attacker when formulating or conducting an attack.

Fix:

For Security Operations:
You should evaluate the production requirements for the found directory. If the directory is not required for production

operation, then the directory and its contents should be removed or restricted by a server access control mechanism. More information about implementing access control schemes can be found in the References. Automatic directory indexing should also be disabled, if applicable.

For Development:

This problem will be resolved by the web application server administrator. In general, do not rely on 'hidden' directories within the web root that can contain sensitive resources or web applications. Assume an attacker knows about the existence of all directories and files on your web site, and protect them with proper access controls.

For QA:

This problem will be resolved by the web application server administrator.

Reference:

Implementing Basic Authentication in IIS

<http://www.microsoft.com/technet/prodtechnol/WindowsServer2003/Library/IIS/abbca505-6f63-4267-aac1-1ea89d861eb4.mspx>

Implementing Basic Authentication in Apache

<http://httpd.apache.org/docs/howto/auth.html#intro>

Attack Request:

GET /scripts/ HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/...TRUNCATED...

Attack Response:

HTTP/1.1 403 Forbidden
Content-Type: text/html
Server: Micro...TRUNCATED...

File Names: ● https://bizsmsraz.telekom.rs:443/scripts/

Low

Web Server Misconfiguration: Unprotected Directory

Summary:

Directory Enumeration vulnerabilities were discovered within your web application. Risks associated with an attacker discovering a directory on your application server depend upon what type of directory is discovered, and what types of files are contained within it. The primary threat, other than accessing files containing sensitive information, is that an attacker can utilize the information discovered in that directory to perform other types of attacks. Recommendations include restricting access to important directories or files by adopting a "need to know" requirement for both the document and server root, and turning off features such as Automatic Directory Listings that provide information that could be utilized by an attacker when formulating or conducting an attack.

Fix:

For Security Operations:

You should evaluate the production requirements for the found directory. If the directory is not required for production operation, then the directory and its contents should be removed or restricted by a server access control mechanism. More information about implementing access control schemes can be found in the References. Automatic directory indexing should also be disabled, if applicable.

For Development:

This problem will be resolved by the web application server administrator. In general, do not rely on 'hidden' directories within the web root that can contain sensitive resources or web applications. Assume an attacker knows about the existence of all directories and files on your web site, and protect them with proper access controls.

For QA:

This problem will be resolved by the web application server administrator.

Reference:

Implementing Basic Authentication in IIS

<http://www.microsoft.com/technet/prodtechnol/WindowsServer2003/Library/IIS/abbca505-6f63-4267-aac1-1ea89d861eb4.mspx>

Implementing Basic Authentication in Apache

<http://httpd.apache.org/docs/howto/auth.html#intro>

Attack Request:

GET /content/ HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/...TRUNCATED...

Attack Response:

HTTP/1.1 403 Forbidden
Content-Type: text/html
Server: Micro...TRUNCATED...

File Names:

- https://bizsmsraz.telekom.rs:443/content/
- https://bizsmsraz.telekom.rs:443/images/

Low

Web Server Misconfiguration: Unprotected Directory**Summary:**

E-Commerce and/or financial-related directories were discovered within your web application during a Directory Enumeration scan. Risks associated with an attacker discovering a directory on your application server depend upon what type of directory is discovered, and what types of files are contained within it. The primary threat, other than accessing files containing sensitive information, is that an attacker can utilize the information discovered in that directory to perform other types of attacks. Recommendations include restricting access to important directories or files by adopting a "need to know" requirement for both the document and server root, and turning off features such as Automatic Directory Listings that provide information that could be utilized by an attacker when formulating or conducting an attack.

Fix:**For Security Operations:**

You should evaluate the production requirements for the found directory. If the directory is not required for production operation, then the directory and its contents should be removed or restricted by a server access control mechanism. More information about implementing access control schemes can be found in the References. Automatic directory indexing should also be disabled, if applicable.

For Development:

This problem will be resolved by the web application server administrator. In general, do not rely on 'hidden' directories within the web root that can contain sensitive resources or web applications. Assume an attacker knows about the existence of all directories and files on your web site, and protect them with proper access controls.

For QA:

This problem will be resolved by the web application server administrator.

Reference:**Implementing Basic Authentication in IIS**

<http://www.microsoft.com/technet/prodtechnol/WindowsServer2003/Library/IIS/abbca505-6f63-4267-aac1-1ea89d861eb4.mspx>

Implementing Basic Authentication in Apache

<http://httpd.apache.org/docs/howto/auth.html#intro>

Attack Request:

GET /account/ HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/...TRUNCATED...

Attack Response:

HTTP/1.1 302 Found
Cache-Control: public, no-store, max-age=0...TRUNCATED...

File Names:

- https://bizsmsraz.telekom.rs:443/account/

Low

Web Server Misconfiguration: Unprotected Directory**Summary:**

IIS/Microsoft product directories were discovered within your web application during a Directory Enumeration scan. Risks associated with an attacker discovering a directory on your application server depend upon what type of directory is

discovered, and what types of files are contained within it. The primary threat, other than accessing files containing sensitive information, is that an attacker can utilize the information discovered in that directory to perform other types of attacks. Recommendations include restricting access to important directories or files by adopting a "need to know" requirement for both the document and server root, and turning off features such as Automatic Directory Listings that provide information that could be utilized by an attacker when formulating or conducting an attack.

Fix:

For Security Operations:

You should evaluate the production requirements for the found directory. If the directory is not required for production operation, then the directory and its contents should be removed or restricted by a server access control mechanism. More information about implementing access control schemes can be found in the References. Automatic directory indexing should also be disabled, if applicable.

For Development:

This problem will be resolved by the web application server administrator. In general, do not rely on 'hidden' directories within the web root that can contain sensitive resources or web applications. Assume an attacker knows about the existence of all directories and files on your web site, and protect them with proper access controls.

For QA:

This problem will be resolved by the web application server administrator.

Reference:

Implementing Basic Authentication in IIS
<http://www.microsoft.com/technet/prodtechnol/WindowsServer2003/Library/IIS/abbca505-6f63-4267-aac1-1ea89d861eb4.mspx>

Attack Request:

GET /aspnet_client/ HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/...TRUNCATED...

Attack Response:

HTTP/1.1 403 Forbidden
Content-Type: text/html
Server: Micro...TRUNCATED...

File Names: ● https://bizsmsraz.telekom.rs:443/aspnet_client/

Low

Web Server Misconfiguration: Unprotected Directory

Summary:

Logfile and/or statistic directories were discovered within your web application during a Directory Enumeration scan. Risks associated with an attacker discovering a directory on your application server depend upon what type of directory is discovered, and what types of files are contained within it. The primary threat, other than accessing files containing sensitive information, is that an attacker can utilize the information discovered in that directory to perform other types of attacks. Recommendations include restricting access to important directories or files by adopting a "need to know" requirement for both the document and server root, and turning off features such as Automatic Directory Listings that provide information that could be utilized by an attacker when formulating or conducting an attack.

Fix:

For Security Operations:

You should evaluate the production requirements for the found directory. If the directory is not required for production operation, then the directory and its contents should be removed or restricted by a server access control mechanism. More information about implementing access control schemes can be found in the References. Automatic directory indexing should also be disabled, if applicable.

For Development:

This problem will be resolved by the web application server administrator. In general, do not rely on 'hidden' directories within

the web root that can contain sensitive resources or web applications. Assume an attacker knows about the existence of all directories and files on your web site, and protect them with proper access controls.

For QA:

This problem will be resolved by the web application server administrator.

Reference:

Implementing Basic Authentication in IIS

<http://www.microsoft.com/technet/prodtechnol/WindowsServer2003/Library/IIS/abbca505-6f63-4267-aac1-1ea89d861eb4.msp>

Implementing Basic Authentication in Apache

<http://httpd.apache.org/docs/howto/auth.html#intro>

Attack Request:

GET /logs/ HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/...TRUNCATED...

Attack Response:

HTTP/1.1 403 Forbidden
Content-Type: text/html
Server: Micro...TRUNCATED...

File Names: ● https://bizsmsraz.telekom.rs:443/logs/

Low	Cookie Security: HTTPOnly not Set
-----	--

Summary:

The web application does not utilize HTTP only cookies. This is a new security feature introduced by Microsoft in IE 6 SP1 to mitigate the possibility of a successful Cross-Site scripting attack by not allowing cookies with the HTTP only attribute to be accessed via client-side scripts. Recommendations include adopting a development policy that includes the utilization of HTTP only cookies, and performing other actions such as ensuring proper filtration of user-supplied data, utilizing client-side validation of user supplied data, and encoding all user supplied data to prevent inserted scripts being sent to end users in a format that can be executed.

Reference:

References:

<https://social.msdn.microsoft.com/Search/en-US?query=HTTPOnly%20Cookie&emptyWatermark=true&ac=5>

Attack Request:

POST /Account/VerifyPhoneNumber HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: https://bizsmsraz.telekom.rs/Account/VerifyPhoneNumber?phoneNumber=0641839461&provider=Phone%20Code
Content-Type: application/x-www-form-urlencoded
Content-Length: 211
Origin: https://bizsmsraz.telekom.rs
Connection: keep-alive
Pragma: no-cache
Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCViz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; .AspNet.TwoFactorCookie=mQcyi1JygR6d2060SIQr-mZVWLLIUPxKLJjk-aiiejXpayJLlJraKV2krI5U39RA9mnwSk2y7bkSGE0y6B5BGyP7Bk7FtLuMpaHTZe9uYts7EuB_ND0PnkmVykrBRHXCe358fXqPN9_saiu-TZLTU3-MSQ_0DxrG5NVZn1SYShNow3x-haTJs3c2-WOSTngsDLJiz59t4rQUADGYabdwTqu5pNxPIUuwCLP-dumObzeUdrSdRnr6IC7v5ElrWhpFIRIVxo5VNsy-N8PFI88x3Xfq-kVWw-jBLPOxpX8ptDDVr05iX4zdFs_9wVEwPSE2cmV5CYZFIogiEavda-gimQ;CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443

Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stdid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="597f6ab5";thid="640";

__RequestVerificationToken=ofkkI5tWGx3GrxicwMG-1x0PH5O4RB0Jt6YFj1ELd2p8mg1tnIaHU9c97XjjReUFoQz5Oel5xmKoLXJ0WmauujbcXPAJFjXFi04ZeeV73E1&UserId=f00b39cc-487e-41ff-a4dd-509ba154c1a7&Provider=Phone+Code&Code=123456

Attack Response:

HTTP/1.1 302 Found
Cache-Control: no-cache
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: -1
Location: /Home/Index
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-AspNet-Version: 4.0.30319
Set-Cookie: .AspNet.TwoFactorCookie=; path=/; expires=Thu, 01-Jan-1970 00:00:00 GMT
Set-Cookie: .AspNet.ApplicationCookie=tk1Tj-x-Po...TRUNCATED...

File Names: ● https://bizsmsraz.telekom.rs:443/Account/VerifyPhoneNumber

Low

Flash Misconfiguration: Vulnerable Flash Engine

Summary:

WebInspect has detected the use of Adobe Flash in your application.

Adobe has deprecated Flash with an end-of-life set to the end of 2020. Flash support has been disabled by default in many browsers, for example Chrome 76 and Firefox 69. Further, starting in December 2020, Chrome, Firefox and Microsoft Edge will completely eliminate support for Flash.

Adobe Flash has had many vulnerabilities associated with it since its inception. Of date there are over 1000 CVE's (Common Vulnerabilities and Exposures) reported against Adobe Flash. Many of which lead to Remote Code Execution, and Cross-Site Scripting attacks that can compromise user and/or system data and privacy.

Consider updating your application to replace Adobe Flash with safer, alternative technologies that provide similar functionality such as HTML5, WebGL and WebAssembly.

Implication:

Use of deprecated and vulnerable technology can enable attackers to compromise the target by exploiting known vulnerabilities against the detected server.

Fix:

Consider replacing the Flash code with safer, alternative technologies such as HTML5, WebGL or WebAssembly.

Reference:

[Flash and The Future of Interactive Content](#)

[CVE Details](#)

Attack Request:

GET /bundles/jquery-datatables-buttons?v=2BPkwBkFU1d_gjeyBUcwuNuxtpD7BYPM358Ff4TbiDw1 HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/Home/SentSMSReport
Host: bizsmsraz.telekom.rs
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Sec-Fetch-Dest: script
Sec-Fetch-Mode: no-cors
Sec-Fetch-Site: same-origin
Pragma: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0

Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
ScriptEngine="Gecko";Category="Crawl";SID="D5B3932C96F7AAD14140197A48371A8E";PSID="6C1A8B9065D844A3C82CDD
E7E06EABF5";SessionType="Crawl";CrawlType="ScriptInclude";AttackType="None";OriginatingEngineID="00000000-0000-
0000-0000-000000000000";tht="21";
X-RequestManager-Memo: std="1113";stmi="0";sc="1";rid="9b4ff916";
X-Request-Memo: rid="d17c449d";sc="1";thid="796";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=vdo9iRP2ld
89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFkr3-9cTNxfeTw7BY8ju3sJy3PCzHjIh1a4oTr0yPtt-
Ic8mUQUmI6XbgvPvNk1;.AspNet.ApplicationCookie=tk1Tj-x-
PoW1x93e5uD2dC4TV2UwYVhp1eWCGbzcEWZGCRieT3nCWlwLeHyK2fjxuB6FMe-
PUku7qTco70stH5utNPSIrS5TmFbcbbODY8w3wuhVP8QX1A0itUqchYKK0j_z5HVRHqKF4CEq3mZxpTOOIq8vvz1ctpO1HBzn-
iXeOd4EmSrR7XTog-Xx_FfmAXcxKszNR23k0dhTHu3GhznYpiwFRVazFso1QgGQkJ4dHzO-
AvxGKoKD3CEeNqOos4NAQB8wb4ValRtSP3RoypoXEnUSZsFXekiCoThknY7XdaT-oAs0T-
jgbEFtnYREHQScJ6jpfFj1a3nRuEcUS58eSa_fu303PBiQOFzsW7kipigde6iF38gtJas7TRf7GMO8e_TVjyxkfK-
Lg21sM1XzfQZiyQaqdJLAvDEo0ysg3vvnVq_G2LP9lNoS4RojBaISRobXCzeA3jGynEkunFZh1TXWMIldQTL2trWASuNep8Pj1TWG2gF
9AcumKjbm;_culture=en-us

Attack Response:

HTTP/1.1 200 OK
Cache-Control: public
Content-Type: text/javascript; charset=utf-8
Expires: Fri, 16 Apr 2027 06:49:34 GMT
Last-Modified: Thu, 16 Apr 2026 06:49:34 GMT
Vary: User-Agent,Accept-Encoding
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:49:33 GMT
Content-Length: 1124288

...TRUNCATED...ame="wmode" value="transparent"/></object>');i+=<embed id="+this.movieId+"
src="+u.moviePath+" loop="false" menu="false" quality="best" bgcolor="#ffffff" width="+n+" height="+t+"
name="+this.movieId+" align="middle" allowScriptAccess="always" allowFullScreen="false" type="application/x-shockwave-
flash" pluginspage="http://www.macromedia.com/go/getflashplayer" flashvars="+r+" wmode="transparent" />
,i},hide:function(){this.div&&(this.div.style.lef...TRUNCATED...

File Names: ● https://bizsmsraz.telekom.rs:443/bundles/jquery-datatables-buttons?
v=2BPkwBkFU1d_gjeyBUcwuNuxtpD7BYP

Low

Web Server Misconfiguration: Unprotected Directory

Summary:

A directory named 'adm' was discovered within your web application during a Directory Enumeration scan. Risks associated with an attacker discovering an administrative directory on your application server typically include the potential for the attacker to use the administrative applications to affect the operations of the web site. Recommendations include restricting access to important directories or files by adopting a "need to know" requirement for both the document and server root, and turning off features such as Automatic Directory Listings that provide information that could be utilized by an attacker when formulating or conducting an attack.

Implication:

Administrative directories typically contain applications capable of changing the configuration of the running software; an attacker who gains access to an administrative application can drastically affect the operation of the web site.

Fix:

For Security Operations:

You should evaluate the production requirements for the found directory. If the directory is not required for production operation, then the directory and its contents should be removed or restricted by a server access control mechanism. More information about implementing access control schemes can be found in the References. Automatic directory indexing should also be disabled, if applicable.

For Development:

This problem will need to be resolved by the web application server administrator. In general, do not rely on 'hidden' directories within the web root that can contain sensitive resources or web applications. Assume an attacker knows about the existence of all directories and files on your web site, and protect them with proper access controls.

For QA:
This problem will be resolved by the web application server administrator.

Reference:

Implementing Basic Authentication in IIS
<http://www.microsoft.com/technet/prodtechnol/WindowsServer2003/Library/IIS/abbca505-6f63-4267-aac1-1ea89d861eb4.mspx>

Authentication, Authorization and Access Control
<http://httpd.apache.org/docs/2.0/howto/auth.html>

Attack Request:

GET /api/home/GetUnsubTextMts/adm/ HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/a...TRUNCATED...

Attack Response:

HTTP/1.1 401 Unauthorized
Cache-Control: no-cache
Pragma: no...TRUNCATED...

- File Names:**
- https://bizsmsraz.telekom.rs:443/api/home/GetUnsubTextMts/adm/
 - https://bizsmsraz.telekom.rs:443/api/home/gettestnumber/adm/
 - https://bizsmsraz.telekom.rs:443/api/home/getgroups/adm/
 - https://bizsmsraz.telekom.rs:443/api/home/GetUnsubtextNotInMts/adm/

Low	Web Server Misconfiguration: Server Error Message
-----	--

Summary:

A server error response was detected. The server could be experiencing errors due to a misbehaving application, a misconfiguration, or a malicious value sent during the auditing process. While error responses in and of themselves are not dangerous, per se, the error responses give attackers insight into how the application handles error conditions. Errors that can be remotely triggered by an attacker can also potentially lead to a denial of service attack or other more severe vulnerability. Recommendations include designing and adding consistent error handling mechanisms which are capable of handling any user input to your web application, providing meaningful detail to end-users, and preventing error messages that might provide information useful to an attacker from being displayed.

Implication:

The server has issued a 500 error response. While the body content of the error page may not expose any information about the technical error, the fact that an error occurred is confirmed by the 500 status code. Knowing whether certain inputs trigger a server error can aid or inform an attacker of potential vulnerabilities.

Fix:

For Security Operations:

Server error messages, such as "File Protected Against Access", often reveal more information than intended. For instance, an attacker who receives this message can be relatively certain that file exists, which might give him the information he needs to pursue other leads, or to perform an actual exploit. The following recommendations will help to ensure that a potential attacker is not deriving valuable information from any server error message that is presented.

- **Uniform Error Codes:** Ensure that you are not inadvertently supplying information to an attacker via the use of inconsistent or "conflicting" error messages. For instance, don't reveal unintended information by utilizing error messages such as Access Denied, which will also let an attacker know that the file he seeks actually exists. Have consistent terminology for files and folders that do exist, do not exist, and which have read access denied.
- **Informational Error Messages:** Ensure that error messages do not reveal too much information. Complete or partial paths, variable and file names, row and column names in tables, and specific database errors should never be revealed to the end user. Remember, an attacker will gather as much information as possible, and then add pieces of seemingly innocuous information together to craft a method of attack.
- **Proper Error Handling:** Utilize generic error pages and error handling logic to inform end users of potential problems. Do not provide system information or other data that could be utilized by an attacker when orchestrating an attack.

Removing Detailed Error Messages

Find instructions for turning off detailed error messaging in IIS at this link:

<http://support.microsoft.com/kb/294807>

For Development:

From a development perspective, the best method of preventing problems from arising from server error messages is to adopt secure programming techniques that prevent problems that might arise from an attacker discovering too much information about the architecture and design of your web application. The following recommendations can be used as a basis for that.

- Stringently define the data type (for instance, a string, an alphanumeric character, etc) that the application will accept.
- Use what is good instead of what is bad. Validate input for improper characters.
- Do not display error messages to the end user that provide information (such as table names) that could be utilized in orchestrating an attack.
- Define the allowed set of characters. For instance, if a field is to receive a number, only let that field accept numbers.
- Define the maximum and minimum data lengths for what the application will accept.
- Specify acceptable numeric ranges for input.

For QA:

The best course of action for QA associates to take is to ensure that the error handling scheme is consistent. Do you receive a different type of error for a file that does not exist as opposed to a file that does? Are phrases like "Permission Denied" utilized which could reveal the existence of a file to an attacker? Inconsistent methods of dealing with errors gives an attacker a very powerful way of gathering information about your web application.

Reference:

Apache:

[Security Tips for Server Configuration](#)
[Protecting Confidential Documents at Your Site](#)
[Securing Apache - Access Control](#)

Microsoft:

[How to set required NTFS permissions and user rights for an IIS 5.0 Web server](#)
[Default permissions and user rights for IIS 6.0](#)
[Description of Microsoft Internet Information Services \(IIS\) 5.0 and 6.0 status codes](#)

Attack Request:

GET /Home/SentSmsDetail?year=2026&month=3&charged=True%26rhppvar%3DRHPP1234 HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/H...TRUNCATED...

Attack Response:

HTTP/1.1 500 Internal Server Error
Cache-Control: private, s-...TRUNCATED...

File Names:

- https://bizsmsraz.telekom.rs:443/Home/SentSmsDetail?year=2026&month=3&charged=True%26rhppvar%3DRHPP1
- https://bizsmsraz.telekom.rs:443/Group/CreateGroup
- https://bizsmsraz.telekom.rs:443/Manage/ChangePassword?%ADd+allow_url_include%3d1+%ADd+auto_prepend_
- https://bizsmsraz.telekom.rs:443/
- https://bizsmsraz.telekom.rs:443/Account/VerifyPhoneNumber
- https://bizsmsraz.telekom.rs:443/Account
- https://bizsmsraz.telekom.rs:443/Account/ResendCode

Summary:

Most recent browsers have features that will save password field content entered by users and then automatically complete password entry the next time the field are encountered. This feature is enabled by default and could leak password since it is stored on the hard drive of the user. The risk of this issue is greatly increased if users are accessing the application from a shared environment. Recommendations include setting autocomplete to "off" on all your password fields.

Please Note: Recent versions of most browsers, as noted below, now ignore the autocomplete="off" attribute for password fields in html forms. Users are allowed to decide the password policy at their own discretion using the password manager. Although setting is ineffective on these versions of browsers, it would continue to protect website users of earlier versions of these and other browsers that support this attribute.

Browsers NOT Supporting autocomplete="off":

Internet Explorer version 11 or above
 Firefox version 30 or above
 Chrome version 34 or above
 For other browsers, please refer to vendor specific documentation

Execution:

To verify if a password field is vulnerable, first make sure to enable the autocomplete in your browser's settings, and then input the other fields of the form to see whether the password is automatically filled. If yes, then it's vulnerable, otherwise, not. You may need to do it twice in case it is the first time you type in the credential in your browser.

Please Note: That some modern browsers no longer support this attribute as summarized above. Verification should be done using a browser that supports this attribute.

Implication:

When autocomplete is enabled, hackers can directly steal your password from local storage.

Fix:

From the web application perspective, the autocomplete can be turned at the form level or individual entry level by defining the attribute AUTOCOMPLETE="off".

Reference:

Microsoft:
[Autocomplete Security](#)

Attack Request:

```
GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
```

Attack Response:

```
HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
```

X-AspNet-Version: 4.0.30319
Set-Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjlhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; path=/; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:48:49 GMT
Content-Length: 4713

```
<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Prijava</title>
  <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

  <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">

          </ul>

        <ul class="nav navbar-nav navbar-right">

          <li><a href="/" id="loginLink">Prijava</a></li>
          <li style="padding-bottom:11px; padding-top:11px;">|</li>
          <li>
            <a href="/Home/SetCulture?culture=en-us">
              <span class="flag-icon flag-icon-gb"></span>
            </a>
          </li>
        </ul>

      </div>
    </div>
    <div class="container body-content">

      <h2>Prijava</h2>
      <div class="row">
        <div class="col-md-12">
          <section id="loginForm">
            <form action="/" class="form-horizontal" method="post" role="form"><input name="__RequestVerificationToken"
            type="hidden" value="QIQ8t8mRUTN0iee6LdzuqQ6IszC6bfJO4waMQZzJhxle-QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZCI39FMpTfTi5TmpXQjCKNKZ881" />          <hr />
            <div class="form-group">
              <label class="col-md-2 control-label" for="Username">Korisničko ime</label>
              <div class="col-md-10">
                <input class="form-control" data-val="true" data-val-required="Korisničko ime je obavezno polje"
                id="Username" name="Username" type="text" value="" />
                <span class="field-validation-valid text-danger" data-valmsg-for="Username" data-valmsg-
                replace="true"></span>
              </div>
            </div>
            <div class="form-group">
              <label class="col-md-2 control-label" for="Password">Lozinka</label>
              <div class="col-md-10">
                <input class="form-control" data-val="true" data-val-required="Lozinka je obavezno polje" id="Password"
                name="Password" type="password" />
                <span class="field-validation-valid text-danger" data-valmsg-for="Password" data-valmsg-
                replace="true"></span>
              </div>
            </div>
          </section>
        </div>
      </div>
    </div>
  </div>
</body>
</html>
```



```

    </div>
  </div>r
    <div class="form-group">
      <div class="col-md-offset-2 col-md-10">
        <div class="checkbox">
          <input data-val="true" data-val-required="The Zapamti me? field is required." id="RememberMe"
name="RememberMe" type="checkbox" value="true" /><input name="RememberMe" type="hidden" value="false" />
          <label for="RememberMe">Zapamti me?</label>
        </div>
      </div>
    </div>
  <div class="form-group">
    <div class="col-md-offset-2 col-md-10">
      <input type="submit" value="Prijava" class="btn btn-default" />
    </div>
  </div>

```

...TRUNCATED...

- File Names:**
- <https://bizsmsraz.telekom.rs:443/>
 - <https://bizsmsraz.telekom.rs:443/Manage/ChangePassword>
 - <https://bizsmsraz.telekom.rs:443/Account/>

Low

Cache Management: Insecure Policy

Summary:

WebInspect has detected a potentially unsafe cache control policy for secure content. While content transmitted over an SSL/TLS channel is expected to guarantee confidentiality, administrators must ensure that caching of sensitive content is disabled unless absolutely needed. The misconception that secure content caching is disabled by default by user-agents could cause the application to fail the organization's cache policy. An unsafe specification such as Cache-Control: public instructs the browser to persistently cache the content on the hard drive. Cache-Control with no-store in the value must be set to prevent browsers from persisting content. Browsers and intermediate proxies will still persists with the no-cache directive. However, they will revalidate the content with the server before serving content from cache. The private directive prevents intermediate proxies from caching content. Missing Cache-Control policy header results in browsers caching content regardless of whether it is served over HTTP or HTTPS.

- Cache-Control: no-store

Execution:

Send a request to <https://bizsmsraz.telekom.rs:443/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOu001> and inspect the Cache-Control header value.

Implication:

Insecure caching policies could lead to content spoofing or information theft.

SSL provides secure encrypted channel to transfer information from source to user. The information served over SSL is considered sensitive and trusted to be only available to the requestor. However, caching this content on disk in temporary internet files or on an intermediate proxy server can compromise that trust by exposing it to anyone who has access to the temporary storage or proxy cache. Content served over SSL should have cache disabled.

Fix:

Set the Cache-Control directive to no-store.

no-cache

For sensitive resources requiring user authentication, servers can send the no-cache directive to prevent caches from serving a cached response without first requiring the user-agent to validate the user identity. This directive can be specified with or without field names. When no field names are included, this directive applies to the entire request or response. When one or more field names are specified in the no-cache directive, the response is cached but the specified fields must be excluded. If the response must include the specified field, then the cache must ensure that the request triggers a revalidation with the origin server.

Example: Cache-Control: no-cache="Set-Cookie"

This directive can be used to prevent sensitive information leakage by requiring the server to confirm the user identity before serving the protected information. While content is not served using the browser's history or back button, a user with disk access can retrieve the content.

no-store

To completely disable the caching of requests or responses, the server must specify the no-store directive in the Cache-Control header. This directive applies to the entire request and response regardless of whether the directive is sent in the request or the response.

Reference:

Server Configuration:

IIS

<http://support.microsoft.com/kb/247404>

Apache

<https://httpd.apache.org/docs/2.4/caching.html>

RFC 9111 Section 5.2 Cache Control

<https://datatracker.ietf.org/doc/html/rfc9111#section-5.2>

Browser Cache FAQ

https://www.owasp.org/index.php/OWASP_Application_Security_FAQ#Browser_Cache

Caching Tutorial

https://www.mnot.net/cache_docs/

Attack Request:

GET /Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe...TRUNCATED...

Attack Response:

HTTP/1.1 200 OK

Cache-Control: public

Content-Type: t...TRUNCATED...

File Names:

- <https://bizsmsraz.telekom.rs:443/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01>

Low

Web Server Misconfiguration: Insecure Content-Type Setting

Summary:

Almost all browsers are designed to use a mime sniffing technique to guess the content type of the HTTP response instead of adhering to the Content-Type specified by the application in specific cases or ignoring the content when no mime type is specified. Inconsistencies introduced by the mime sniffing techniques could allow attackers to conduct Cross-Site Scripting attacks or steal sensitive user data. WebInspect has determined that the application fails to instruct the browser to strictly enforce the Content-Type specification supplied in the response.

Web server misconfiguration can cause an application to send HTTP responses with the missing Content-Type header or specify a mime type that does not match up accurately with the response content. When a browser receives such a response, it attempts to programmatically determine the mime type based on the content returned in the response. The mime type derived by the browser, however, might not accurately match the one intended by the application developer. Such inconsistencies have historically allowed attackers to conduct Cross-Site Scripting or data theft using Cascading Style Sheets (CSS) by letting them bypass server-side filters using mime type checking and yet have the malicious payload with misleading mime type specification executed on the client-side due to the browser mime sniffing policies.

Microsoft Internet Explorer (IE) introduced the X-Content-Type-Options: nosniff specification that application developers can include in all responses to ensure that mime sniffing does not occur on the client-side. This protection mechanism is limited to Microsoft Internet Explorer versions 9 and above.

Execution:

- . Build a test page that includes a reference to an external JavaScript or CSS resource
- . Configure the server to return the external resource with an incorrect mime type specification
- . Visit the test page using an old version of Microsoft's Internet Explorer (version IE 8) browser
- . Interpretation of the external content as JavaScript or CSS by the browser despite the misleading mime type specification indicates a potential for compromise.

Implication:

By failing to dictate the suitable browser interpretation of the response content, application developers can expose their users to Cross-Site Scripting or information stealing attacks.

Fix:

- Configure the web server to always send the X-Content-Type-Options: nosniff specification in the response headers. In addition, ensure that following safety precautions are also put in place:
- . Verify that the web server configuration will send the accurate mime type information in the Content-Type header of each HTTP response
 - . Configure the server to send a default Content-Type of text-plain or application/octet-stream to tackle failure scenarios
 - . Ensure that appropriate Character Set is specified in the Content-Type header
 - . Configure the server to send Content-Disposition: attachment; filename=name; for content without an explicit content type specification.

Reference:

- Microsoft Internet Explorer:**
[MIME-Handling Change: X-Content-Type-Options: nosniff](#)
[MIME-Handling Changes in Internet Explorer](#)
- OWASP:**
[OWASP Testing Guide Appendix D: Encoded Injection](#)
[List of Useful HTTP Headers](#)
- CSS Data Theft:**
[CVE-2010-0654](#)

Attack Request:

GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stdid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443

Attack Response:

HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modif...TRUNCATED...

File Names: ● https://bizsmsraz.telekom.rs:443/

Low

Web Server Misconfiguration: Unprotected Directory

Summary:

Development-related directory - **.git** was discovered within your web application during a Site Search scan. Risks associated with an attacker discovering a directory on your application server depend upon what type of directory is discovered, and what types of files are contained within it. The primary threat other than accessing files containing sensitive information, is that an attacker can utilize the information discovered in that directory to perform other types of attacks. Recommendations

include removing any source code directories and repositories from the production server, disabling the use of remote repositories, and ensuring that the latest patches and version updates have been performed on the version control system being used. Additionally, restrict access to important directories or files by adopting a "need to know" requirement for both the document and server root, and turning off features such as Automatic Directory Listings that provide information that could be utilized by an attacker when formulating or conducting an attack.

Execution:

Browse to <https://bizmsraz.telekom.rs:443/api/home/getgroups/.git/> and inspect the content. Response should return with HTTP status code 200 and should not match target site's file not found response.

Implication:

An attacker may use the internal information obtained from the source code files to craft a precise attack against the web application. Such attacks can include, but are not limited to, SQL injection, remote file system access, malware injection and database manipulation.

Fix:

For Security Operations:

You should evaluate the production requirements for the found directory. If the directory is not required for production operation, then the directory and its contents should be removed or restricted by a server access control mechanism. More information about implementing access control schemes can be found in the References. Automatic directory indexing should also be disabled, if applicable.

For Development:

This problem will be resolved by the web application server administrator. In general, remove all source code repositories and files from the production server and do not rely on 'hidden' directories within the web root that can contain sensitive resources or web applications. Assume an attacker knows about the existence of all directories and files on your web site, and protect them with proper access controls.

For QA:

This problem will be resolved by the web application server administrator.

Attack Request:

GET /api/home/getgroups/.git/ HTTP/1.1
Referer: https://bizmsraz.telekom.rs/a...TRUNCATED...

Attack Response:

HTTP/1.1 401 Unauthorized
Cache-Control: no-cache
Pragma: no...TRUNCATED...

File Names:

- <https://bizmsraz.telekom.rs:443/api/home/getgroups/.git/>
- <https://bizmsraz.telekom.rs:443/api/home/GetUnsubtextNotInMts/.git/>
- <https://bizmsraz.telekom.rs:443/api/home/GetUnsubTextMts/.git/>
- <https://bizmsraz.telekom.rs:443/api/home/gettestnumber/.git/>

Low	HTML5: Missing Content Security Policy
-----	--

Summary:

Content Security Policy (CSP) is an HTTP response security header that developers and security architects can leverage to create an allow list of domains from which the site is allowed to load resources. This header provides an in-depth security protection from critical vulnerabilities such as cross-site scripting and clickjacking. Additionally, CSP restricts execution of inline JavaScript, dynamic JavaScript code evaluation from strings, and framing of the site from external domains. While CSP is not a replacement for input validation, it can help to significantly reduce the risk of XSS from unknown weaknesses. The CSP frame-ancestors directive is equivalent to X-Frame-Options and restricts the domain that are allowed to frame the site's content.

Execution:

Access link <https://bizmsraz.telekom.rs:443/> through a proxy and notice the missing CSP header in the response. By default, WebInspect flags only one instance of this vulnerability per host because it is typical to set this header at the host level in a server configuration.

Perform the following steps to flag all instances of this issue:

- Create a new policy with the selection of checks that you want to include in a rescan. We recommend using the Blank or Passive policy as a base.
- Select this check and uncheck the "FlagAtHost" check input from standard description.
- Save the policy.
- Rescan with this new custom policy.

Implication:

Security architects and developers can leverage CSP to significantly reduce the risk of XSS and clickjacking attacks. CSP headers can restrict leakage of information to external domains by restricting which domains the site is allowed to load contents from when rendered in browser .

Fix:

Define a CSP policy suitable for your site. The policy can be set either with an HTTP response header or <meta /> tag.

For example:

```
Content-Security-Policy: default-src https://example.net; child-src 'none';
```

Or

```
<meta http-equiv="Content-Security-Policy" content="default-src https://cdn.example.net;  
child-src 'none'; object-src 'none'">
```

Content-Security-Policy 2 is the recommended standard. Content-Security-Policy 3 is in draft. The following is a snapshot of modern browser support for the CSP header:

- Edge: Versions 15-18; supported with a nonce bug. Version 75 and later; fully supported.
- Chrome: Versions 36-38; missing the plugin-types, child-src, frame-ancestors, base-uri, and form-action directives. Version 39; missing the plugin-types, child-src, base-uri, and form-action directives. Version 40 and later; fully supported.
- Firefox: Versions 31-34; missing the plugin-types, child-src, frame-ancestors, base-uri, and form-action directives. Version 35; missing the plugin-types, child-src, frame-ancestors, and form-action directives. Versions 36-44; missing the plugin-types and child-src directives. Version 45 and later; missing the plugin-types directive.

Furthermore, the report-uri directive can be configured to receive reports of attempts to violate the policy. These reports can be used as an early indication of security issues in the site as well as to optimize the policy.

Reference:

[Content Security Policy Level 3](#)

[OWASP Content Security Policy](#)

[MDN web docs](#)

[Content Security Policy \(CSP\) Quick Reference Guide](#)

Attack Request:

```
GET / HTTP/1.1  
Host: bizsmsraz.telekom.rs  
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0  
Accept: */*  
Accept-Language: en-US,en;q=0.5  
Accept-Encoding: gzip, deflate  
Connection: keep-alive  
Sec-Fetch-Dest: document  
Sec-Fetch-Mode: navigate  
Sec-Fetch-Site: same-origin  
Priority: u=0, i  
X-WIPP: AscVersion=25.4.0.57  
X-RequestManager-Memo: std="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";  
X-Request-Memo: rid="7810b0c4";thid="601";  
Pragma: no-cache  
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
```

Attack Response:

```
HTTP/1.1 200 OK  
Cache-Control: public, no-store, max-age=0  
Content-Type: text/html; charset=utf-8  
Expires: Thu, 16 Apr 2026 06:48:49 GMT  
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT  
Vary: *  
Server: Microsoft-IIS/10.0  
X-AspNetMvc-Version: 5.2  
X-Frame-Options: SAMEORIGIN  
X-AspNet-Version: 4.0.30319  
Set-Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-  
9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; path=/; HttpOnly  
X-Powered-By: ASP.NET  
Strict-Transport-Security: max-age=31536000; includeSubDomains  
Date: Thu, 16 Apr 2026 06:48:49 GMT  
Content-Length: 4713
```

```
<!DOCTYPE html>
```

```

<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Prijava</title>
  <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

  <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">

          </ul>

        <ul class="nav navbar-nav navbar-right">

          <li><a href="/" id="loginLink">Prijava</a></li>
          <li style="padding-bottom:11px; padding-top:11px;"></li>
          <li>
            <a href="/Home/SetCulture?culture=en-us">
              <span class="flag-icon flag-icon-gb"></span>
            </a>
          </li>
        </ul>

      </div>
    </div>
    <div class="container body-content">

      <h2>Prijava</h2>
      <div class="row">
        <div class="col-md-12">
          <section id="loginForm">
            <form action="/" class="form-horizontal" method="post" role="form"><input name="__RequestVerificationToken"
            type="hidden" value="QIQ8mRUTN0iee6LdzuqQ6IszC6bfJO4waM0QZzJhxle-
            QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZCI39FMpTfTi5TmPXQjCKNKZ881" />          <hr />
            <div class="form-group">
              <label class="col-md-2 control-label" for="Username">Korisničko ime</label>
              <div class="col-md-10">
                <input class="form-control" data-val="true" data-val-required="Korisničko ime je obavezno polje"
                id="Username" name="Username" type="text" value="" />
                <span class="field-validation-valid text-danger" data-valmsg-for="Username" data-valmsg-
                replace="true"></span>
              </div>
            </div>
            <div class="form-group">
              <label class="col-md-2 control-label" for="Password">Lozinka</label>
              <div class="col-md-10">
                <input class="form-control" data-val="true" data-val-required="Lozinka je obavezno polje" id="Password"
                name="Password" type="password" />
                <span class="field-validation-valid text-danger" data-valmsg-for="Password" data-valmsg-
                replace="true"></span>
              </div>
            </div>
            <div class="form-group">
              <div class="col-md-offset-2 col-md-10">
                <div class="checkbox">
                  <input data-val="true" data-val-required="The Zapamti me? field is required." id="RememberMe"
                  name="RememberMe" type="checkbox" value="true" /><input name="RememberMe" type="hidden" value="false" />
                  <label for="RememberMe">Zapamti me?</label>
                </div>
              </div>
            </div>
          </section>
        </div>
      </div>
    </div>
  </div>

```

```

</div>
<div class="form-group">
  <div class="col-md-offset-2 col-md-10">
    <input type="submit" value="Prijava" class="btn btn-default" />
  </div>
</div>

```

...TRUNCATED...

File Names: ● <https://bizsmsraz.telekom.rs:443/>

Low

Cookie Security: Missing SameSite Attribute

Summary:

The SameSite attribute protects cookies from Cross-Site Request Forgery (CSRF) attacks. The browser automatically appends cookies to every HTTP request made to the site that sets the cookie. Cookies might store sensitive data like session ID and authorization token or site data that is shared between different requests to the same site during a session. An attacker can perform an impersonation attack by generating a request to the authenticated site from a third-party site page loaded on the client machine because the browser automatically appended the cookie to the request.

The SameSite attribute on a cookie allows sites to control that behaviour and prevents browsers from appending the cookie to request if the request is generated from a third-party site page load. The SameSite attribute can have the following three values:

- Strict: When set to Strict, cookies are only sent along with requests upon top level navigation .
- Lax: When set to Lax, cookies are sent with top level navigation from the same host as well as GET requests originated to the host from third-party sites (for example, in iframe, link, href, and so on and the form tag with GET method only).
- None: Cookies are sent in all requests made to the site within the path and domain scope set for the cookie. Requests generated due to form submissions using the POST method are also allowed to send cookies with request.

Please note that cookies that have the SameSite attribute with the value of None must be set with the Secure attribute otherwise the browser rejects the cookies. Additionally, a few specific browser versions reject the SameSite cookie with the None value for example, Chrome versions 51 to 66, versions of the UC Browser on Android prior to version 12.13.2, versions of Safari and embedded browsers on macOS 10.14, and all browsers on iOS 12 reject cookies set with SameSite=None. A suggested workaround for this issue is to set an alternate cookie with a prefix or suffix such as *Legacy* appended to cookienam . Sites can look for this legacy cookie if it does not find a cookie that was set with SameSite=None.

Execution:

Inspect the highlighted cookie value in the HTTP response in the vulnerable session. The cookie is missing the SameSite attribute.

Implication:

Sites that set cookies without the SameSite attribute have an increased risk of CSRF attacks. Using CSRF, an attacker can impersonate a valid user and gain unauthorized access to application functionality. Furthermore, the recent versions of browsers might reject the cookie that is not set with the SameSite attribute.

Fix:

Add the SameSite attribute to all cookies. Starting February 2020, the Chrome browser made SameSite a mandatory attribute for all cookies. Any cookie without the SameSite attribute is either rejected or treated with the default behaviour, which is the same as setting the attribute value to Lax. Therefore, any cookie that must be sent regardless the origination of the request (for example, analytics cookies) should have the SameSite attribute value of none.

Furthermore, we recommend that developers continue to add traditional CSRF mitigations to the site along with SameSite attribute. Many site users might still use older browser versions to access the site. Older browser versions do not understand the SameSite attribute.

Reference:

<https://tools.ietf.org/html/draft-ietf-httpbis-rfc6265bis-05>
<https://www.chromium.org/updates/same-site/incompatible-clients>
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie/SameSite>

Attack Request:

```

GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin

```

Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443

Attack Response:

HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
Set-Cookie:
_RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCViz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; path=/; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security...TRUNCATED...

File Names: ● https://bizsmsraz.telekom.rs:443/

Low

Cache Management: Web Cache Poisoning

Summary:

WebInspect has detected a web cache poisoning instance by fat GET requests. Fat GET requests are requests that contain parameters as request body. Web cache poisoning exploits the behaviour of the web server causing a malicious response to be served to legitimate requests. In this type of web cache poisoning, the cache key is derived from the original query parameters passed in the request line. However, the value of the query parameter used by the server is the duplicate value sent as part of the request body. This altered response is cached and served to the users with legitimate requests.

WebInspect has detected that the cache can be poisoned. The _ was passed in the request body and it is observed that the initial response differed from the later response for the same query. This indicates that the cache might be poisoned.

Execution:

To test for web cache poisoning, execute the following steps:

The cache-buster is a query parameter added to a URL for example, `cacheBuster=someRandomValue`. Add a cache-buster to the URL.
Add the query parameter as part of the request body for example `param=someRandomValue`.
Send the request and wait for the response.
Next, remove the request body and send the request.
The response received is the malicious cached response.

Implication:

If the web server is susceptible to web cache poisoning, it can lead to legitimate users being served malicious responses.

Fix:

FAT GET requests must not be accepted. Either prune the request body or do not accept such a request.

Reference:

[Web Cache Poisoning](#)

Attack Request:

GET /api/Group/GetListNumbers?_=1776322173178&cacheBuster=WEBINSPECT1286867964 HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/Group/ListNumbers
Host: bizsmsraz.telekom.rs
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
X-Requested-With: XMLHttpRequest
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: same-origin

Pragma: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
Category="Audit.Attack";SID="3B65F066E4A76B64D6C8AC6681D0A181";PSID="651FDC50B737952659F0FFB61AD6EBC8";SessionType="AuditAttack";CrawlType="None";AttackType="Recheck";OriginatingEngineID="c3c565f2-8476-4c98-ada7-ca9411499956";AttackSequence="0";AttackParamDesc="";AttackParamIndex="0";AttackParamSubIndex="0";CheckId="11671";Engine="Web+Cache+Poisoning+Fat+Get";SmartMode="4";tbt="40";
X-RequestManager-Memo: stid="1181";stmi="0";sc="1";rid="fe150613";
X-Request-Memo: rid="a4b2b961";sc="1";thid="753";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=wm7_A0zFEuuwDTqvEidfgAKRe3EWyvP_WDtCw_DdSpTu3k9oBBynOA2RnZQQ0shQqFITEY3mZgvnOqQQ7Lo9peN9fw6PQFFGmfB0aBh9nmU1;.AspNet.ApplicationCookie=7YFkxspcc9O0sjzcF1Q6W4JepMt25M08JqHFU5ZBvU_7wONe59NHf6ha8A9TykRjbE4PHvDXjWkjTWWMHrY02ztFxfRj5tL1Xuq_PGa8HDnVjmLzJIUauV5A7qWtcFFiZo_OFhSae6hh48iBsAlWEvlcnVDEeXGlcEeYdhzX0H1cF-y0gFZJPzPuAW0U9ctu0wsiimvjGre0EQGYsvfprWGBSCwzqxkyn4ZcJlvr9fzcNiY7r8LIU3rl8ahIwDikEqKDoYAtAntj32Y4jh3GCrBONG2BUnbq8DfPg5ruugNOUbbxavvZ6SmpQPBs2TZ1gDNio2Drfb5wL3D27V3WfW-ObQ-NuJNCFSJQVMiurhCXxAg5hHxkwiQOshYxATqKa8X2s_IcfDpl-HMbTCGe5f2y08NJrppXz7QHTRWb4Irt5EegLWVO3zAoJ9NS0sFJbn5KQP0IYqCasX1AoRY73H43UTp1QFGvVvbHxQEduUdcUD0LtuM8A32vcOb_4K;_culture=sr

Attack Response:

HTTP/1.1 200 OK
Cache-Control: no-cache
Pragma: no-cache
Content-Type: application/json; charset=utf-8
Expires: -1
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 07:04:57 GMT
Content-Length: 281712

```
{
  "data": [
    {
      "EditLink": "<a href='\"/Group/EditListNumber/49238\">Izmeni</a>",
      "Number": "0678910112",
      "Name": "Bvz",
      "NumberType": "VAN MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/49239\">Izmeni</a>",
      "Number": "066333222",
      "Name": "Test",
      "NumberType": "U MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/49327\">Izmeni</a>",
      "Number": "0646505227",
      "Name": "Ivan Tr",
      "NumberType": "U MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/49328\">Izmeni</a>",
      "Number": "063467415",
      "Name": "Ivan Vip",
      "NumberType": "VAN MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/76457\">Izmeni</a>",
      "Number": "0646504264",
      "Name": "Sandra",
      "NumberType": "U MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/76458\">Izmeni</a>",
      "Number": "0637561277",
      "Name": "Milan",
      "NumberType": "U MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/205990\">Izmeni</a>",
      "Number": "0648736415",
      "Name": "OLIVERA DRAŽIĆ",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/205991\">Izmeni</a>",
      "Number": "0648736416",
      "Name": "MIRA",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/205992\">Izmeni</a>",
      "Number": "0648736417",
      "Name": "BRANKA",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/205993\">Izmeni</a>",
      "Number": "0648736418",
      "Name": "DRAGANA",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/205994\">Izmeni</a>",
      "Number": "0648736419",
      "Name": "PETAR",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/205995\">Izmeni</a>",
      "Number": "0648736420",
      "Name": "DRAGAN",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/205996\">Izmeni</a>",
      "Number": "0648736421",
      "Name": "IGOR STOŠIĆ",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/205997\">Izmeni</a>",
      "Number": "0648736422",
      "Name": "JANKO",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/205998\">Izmeni</a>",
      "Number": "0648736423",
      "Name": "JELENA",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/205999\">Izmeni</a>",
      "Number": "0648736424",
      "Name": "ZORICA",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/206000\">Izmeni</a>",
      "Number": "0648736425",
      "Name": "SEKRETARICE",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/206001\">Izmeni</a>",
      "Number": "0648736426",
      "Name": "MARIJA ŽERAJIĆ",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/206002\">Izmeni</a>",
      "Number": "0648736427",
      "Name": "ANA",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/206003\">Izmeni</a>",
      "Number": "0648736428",
      "Name": "DEJAN AČIMOVIĆ",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/206004\">Izmeni</a>",
      "Number": "0648736429",
      "Name": "MILA",
      "NumberType": "VPN",
      "EditLink": "<a href='\"/Group/EditListNumber/212798\">Izmeni</a>",
      "Number": "0658882475",
      "Name": "VK1",
      "NumberType": "U MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/212799\">Izmeni</a>",
      "Number": "063209733",
      "Name": "VK2",
      "NumberType": "VAN MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/212800\">Izmeni</a>",
      "Number": "0603907578",
      "Name": "VK3",
      "NumberType": "VAN MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/212801\">Izmeni</a>",
      "Number": "0653030866",
      "Name": "VK4",
      "NumberType": "U MTS",
      "EditLink": "<a href='\"/Group/EditListNumber/212802\">Izmeni</a>"
    }
  ]
}
```

href="/Group/EditListNumber/212802">Izmeni","Number":"0642941097","Name":"VK5","NumberType":"U MTS"},
{ "EditLink": "<a href='/Group/EditListNumber/212803
'>Izmeni","Number":"0644203191","Name":"VK6","NumberType":"U MTS"}, {"EditLink": "Izmeni","Number":"0641301979","Name":"VK7","NumberType":"VAN MTS"},
{ "EditLink": "<a href='/Group/EditListNumber/212805
'>Izmeni","Number":"0641118419","Name":"VK8","NumberType":"U MTS"}, {"EditLink": "Izmeni","Number":"0652450900","Name":"VK9","NumberType":"U MTS"},
{ "EditLink":

...TRUNCATED...

File Names:

- https://bizsmsraz.telekom.rs:443/api/Group/GetListNumbers?_=1776322173178&cacheBuster=WEBINSPECT1286

Informational	Hidden Field
Summary: While preventing display of information on the web page itself, the information submitted via hidden form fields is easily accessible, and could give an attacker valuable information that would prove helpful in escalating his attack methodology. Recommendations include not relying on hidden form fields as a security solution for any area of the web application that contains sensitive information or access to privileged functionality such as remote site administration functionality.	
Execution: Any attacker could bypass a hidden form field security solution by viewing the source code of that particular page.	
Implication: The greatest danger from exploitation of a hidden form field design vulnerability is that the attacker will gain information that will help in orchestrating a far more dangerous attack.	
Fix: Do not rely on hidden form fields as a method of passing sensitive information or maintaining session state. One workable bypass is to encrypt the hidden values in a form, and then decrypt them when that information is to be utilized by a database operation or a script. From a security standpoint, the best method of temporarily storing information required by different forms is to utilize a session cookie. Whether hidden or not, if your site utilizes values submitted via a form to construct database queries, do not make the assumption that the data is non-malicious. Instead, utilize the following recommendations to sanitize user supplied input. • Stringently define the data type (for instance, a string, an alphanumeric character, etc) that the application will accept. • Use what is good instead of what is bad. • Validate input for improper characters. • Do not display error messages to the end user that provide information (such as table names) that could be utilized in orchestrating an attack. • Define the allowed set of characters. For instance, if a field is to receive a number, only let that field accept numbers. • Define the maximum and minimum data lengths for what the application will accept. • Specify acceptable numeric ranges for input.	
Attack Request: GET /Group/CreateGroup HTTP/1.1 Referer: https://bizsmsraz.telekom.rs/Group/Index Accept: */* Pragma: no-cache Accept-Encoding: gzip, deflate User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0 Host: bizsmsraz.telekom.rs Connection: Keep-Alive X-WIPP: AscVersion=25.4.0.57	

X-Scan-Memo:
Category="Crawl";SID="70543A3BEDC62887521C345ABA867086";PSID="A6785A28256A6A9425C940191C268D9D";SessionType="Crawl";CrawlType="HTML";AttackType="None";OriginatingEngineID="00000000-0000-0000-0000-000000000000";AttributeName="href";Format="Relative";LinkKind="HyperLink";Locations="HtmlNode";Source="ScriptExecution";tht="31";
X-RequestManager-Memo: stid="1113";stmi="0";sc="1";rid="fc2db581";
X-Request-Memo: rid="3f23cead";sc="1";thid="565";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=SpTCRhsr4vqPYIuekIn1qSIIOkQDb4TBjGQx7VhaJL3s_ILp8Asj8mmVXsI7iBwbKEI4vB3QwNk8ukDk6bPxprTwaRH59_7UUIlI1x8QTi41;.AspNet.ApplicationCookie=sjNAI43xJIoOrJv-Tp5boJ6zDjQ1dFjZxJZ-JmIwHWPID5qqTc5wrUaW1oeMGFivAymixgCvRDTRdd59nBVA7zrGMnGjRQqCQomu4hZNB_AmOojaL20XR92-Zwfn_-m9-HcmsIcwgsk2YDhd2hgm2Rmi2xx-AAb2zRUxEFWNe9zzAyeWmhuZGUjNdhJGoaaVxBR4MV2_NikIygyR_OVMdfm5oK4Q1w-DKfdFkLtg7noeF90P9S_sOTF3tQdZMzbCN6OXMi-kpesOLMhTxZiARWF1HwB3Fq07aMCII-FGHxXc5iT4DLrtHJMY76NipTdvu600xRGgX14wCB0tHkCk6C67aYExos4P1hN7wJEbi-0uB7AFapV56p6hMeMcrSFLQVBUJlrXK6IJgFOxsM8knH80th8wKo-X_Riz80M-X9xcF3vCT3a6oo-g9LFLI1KJSShJxhjO1gVZ0e9okfrUGUy4G-G8NqQIVLBXk3YdpNbI14neNh5972zKc1Lnydwc;_culture=en-us

Attack Response:

HTTP/1.1 200 OK
Cache-Control: private, s-maxage=0
Content-Type: text/html; charset=utf-8
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:53:56 GMT
Content-Length: 6087

...TRUNCATED...right" id="logoutForm" method="post"><input name="RequestVerificationToken" type="hidden" value="ZJoH90u0-ad07AUwyjmyfe-KORO...TRUNCATED...

File Names:

- https://bizsmsraz.telekom.rs:443/Group/CreateGroup
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213171
- https://bizsmsraz.telekom.rs:443/Home/SentSmsDetail?year=2026&month=4&charged=True
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213172
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213173
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213174
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213163
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213164
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213165
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213166
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213167
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213168
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213169
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213170
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213131
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213132
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213133
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213134
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213135
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213137
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213138
- https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213139

- opentext™**

- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213103>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213104>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213105>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213106>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213107>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213108>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213109>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213110>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213111>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213112>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213113>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213114>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213115>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213116>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213117>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213118>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213119>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213120>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213122>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213123>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213124>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213125>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213126>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213127>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213128>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213129>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213130>
- <https://bizsmsraz.telekom.rs:443/Account/VerifyPhoneNumber?phoneNumber=0641839461&provider=Phone%20C>
- <https://bizsmsraz.telekom.rs:443/>
- <https://bizsmsraz.telekom.rs:443/Home/SendSMS>
- <https://bizsmsraz.telekom.rs:443/Home/SentSMSReport>
- <https://bizsmsraz.telekom.rs:443/Group/ListNumbers>
- <https://bizsmsraz.telekom.rs:443/Manage/ChangePassword>
- <https://bizsmsraz.telekom.rs:443/Account/ResendCode>
- <https://bizsmsraz.telekom.rs:443/>
- <https://bizsmsraz.telekom.rs:443/Home/Index>
- <https://bizsmsraz.telekom.rs:443/Account/VerifyPhoneNumber>
- <https://bizsmsraz.telekom.rs:443/Group/Index>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205990>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205991>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205992>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205993>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205994>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205995>

- opentext™**

- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212834>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212835>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212836>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212837>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212838>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212839>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212840>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212841>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212842>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212843>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213025>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213026>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213027>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213028>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213029>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213121>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213030>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213031>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/297473>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213032>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/297112>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213033>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/255887>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213034>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/255484>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213035>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/295969>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213036>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213055>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213037>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/301312>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213038>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213136>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213039>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213063>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213040>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/49238>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213041>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213042>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213043>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213044>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213045>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213046>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213047>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213048>

- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213049>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213050>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213051>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213052>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213053>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213054>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213056>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213058>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213059>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213060>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213061>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213062>

Informational

Flash Misconfiguration: Source Code Disclosure

Summary:

A Flash movie or Flash object was found. Flash movies and objects can be decompiled and may contain sensitive information. An attacker could decompile the Flash file and gain access to the confidential information, including any hard-coded passwords and keys, within the Flash file.

Execution:

A primary tool in the arsenal of the attacker who wants to get inside your code is the decompiler. A decompiler takes an executable file and attempts to re-create the original source code. It may be almost impossible to go from machine code to a high-level language. It is, however, easy to recover an assembly language version of the program.

Implication:

The attacker's goal in re-creating the original source code may include one or more of the following:

- To steal a valuable algorithm for use in his own code
- To understand how a security function works to enable him to bypass it
- To extract confidential information, such as hard-coded passwords and keys
- To enable him to alter the code so that it behaves in a malicious way

Reference:

Flare - Flash Decompiler

<http://www.nowrap.de/flare.html>

Attack Request:

```
GET /bundles/jquery-datatables-buttons?v=2BPkwBkFU1d_gjeyBUcwuNuxtpD7BYPM358Ff4TbiDw1 HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/Home/SentSMSReport
Host: bizsmsraz.telekom.rs
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Sec-Fetch-Dest: script
Sec-Fetch-Mode: no-cors
Sec-Fetch-Site: same-origin
Pragma: no-cache
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
ScriptEngine="Gecko";Category="Crawl";SID="D5B3932C96F7AAD14140197A48371A8E";PSID="6C1A8B9065D844A3C82CDD
E7E06EABF5";SessionType="Crawl";CrawlType="ScriptInclude";AttackType="None";OriginatingEngineID="00000000-0000-
0000-0000-000000000000";tht="21";
X-RequestManager-Memo: stid="1113";stmi="0";sc="1";rid="9b4ff916";
X-Request-Memo: rid="d17c449d";sc="1";thid="796";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=vdo9iRP2ld
89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-
```


lc8mUQUmI6XbgvPvNk1;.AspNet.ApplicationCookie=tk1Tj-x-
PoW1x93e5uD2dC4TV2UwYVhp1eWCGbzcEWZGCRieT3nCwLwLeHyK2fjxuB6FMe-
PUku7qTco70stH5utNPSIrS5TmFbcbbODY8w3wuhVP8QX1A0itUqchYKK0j_z5HVRHqKF4CEq3mZXpTOOIq8vvz1ctpO1HBzn-
iXeOd4EmSrR7XTog-Xx_FmAXcxKszNR23k0dhTHu3GhznYpiwFRVazFso1QgGQkJ4dHzO-
AvxGKoKD3CEeNqOos4NAQB8wb4ValRtSP3RoypoXEnUSZsFXekiCoThknY7XdaT-oAs0T-
jgbEFtnYREHQScJ6jpFfJ1a3nRuEcUS58eSa_fu303PBiQOFzsW7kipigde6iF38gtJas7TRf7GMO8e_TVjyxkfK-
Lg21sM1XzfqZiyQaqdJLAVDeO0ysg3vvvVq_G2LP9iNoS4RojBaLSRobXCzeA3jGynEkunFZh1TXWMldQTL2trWASuNep8Pj1TWG2gF
9AcumKjbM;_culture=en-us

Attack Response:

HTTP/1.1 200 OK
Cache-Control: public
Content-Type: text/javascript; charset=utf-8
Expires: Fri, 16 Apr 2027 06:49:34 GMT
Last-Modified: Thu, 16 Apr 2026 06:49:34 GMT
Vary: User-Agent,Accept-Encoding
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:49:33 GMT
Content-Length: 1124288

...TRUNCATED...ame="wmode" value="transparent"/><\object>');i+=<embed id="" +this.movieId+"
src="" +u.moviePath+" loop="false" menu="false" quality="best" bgcolor="#ffffff" width="" +n+" height="" +t+"
name="" +this.movieId+" align="middle" allowScriptAccess="always" allowFullScreen="false" type="application/x-shockwave-
flash" pluginspage="http://www.macromedia.com/go/getflashplayer" flashvars="" +r+" wmode="transparent" />
,i},hide:function(){this.div&&(this.div.style.lef... TRUNCATED...

File Names: ● https://bizsmsraz.telekom.rs:443/bundles/jquery-datatables-buttons?v=2BPkwBkFU1d_gjeyBUCwuNuxtpD7BYP

Informational

Web Server Misconfiguration: Weak Authentication

Summary:

The web server sent a 401 "Authorization Required" status code with a response that did not contain a WWW-Authenticate HTTP header. This means the server is asking for authentication, but the browser is not prompting for authentication because of the missing WWW-Authenticate header. Recommendations include reviewing the web pages to determine if they should be protected via authentication, and correct the web server or application configuration to correct the problem by setting the 401 "Authorization Required" status code or by removing the WWW-Authenticate header.

Implication:

To prompt for user authentication, a web server must send a 401 "Authorization Required" status code, along with a WWW-Authenticate HTTP header. This could mean portions of the web site are available that should require authentication, or this may simply be a misconfiguration at the application or web server level.

Fix:

- For Security Operations:**
Review the web pages to determine if they should be protected via authentication, and correct the web server or application configuration to correct the problem by sending a WWW-Authenticate header or by changing the 401 "Authorization Required" status code to a different status.
- For Development:**
Review the web pages to determine if they should be protected via authentication, and correct the web server or application configuration to correct the problem by sending a WWW-Authenticate header or by changing the 401 "Authorization Required" status code to a different status.
- For QA:**
Review the web pages to determine if they should be protected via authentication, and correct the web server or application configuration to correct the problem by sending a WWW-Authenticate header or by changing the 401 "Authorization Required" status code to a different status.

Reference:

RFC-2616
[Section 10.4.2: 401 Unauthorized](#)
[Section 14.47: WWW-Authenticate](#)

Attack Request:

```
GET /api/home/getgroups/ HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/Home/SendSMS
Host: bizsmsraz.telekom.rs
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
X-Requested-With: XMLHttpRequest
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-...TRUNCATED...
```

Attack Response:

```
HTTP/1.1 401 Unauthorized
Cache-Control: no-cache
Pragma: no-cache
Expires: -1
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 07:05:05 GMT
Content-L
```

File Names: ● <https://bizsmsraz.telekom.rs:443/api/home/getgroups/>

Informational

Information Discovery: Session Token

Summary:

The following Session Tokens have been identified in this website:

```
1. .AspNet.TwoFactorCookie=uA178n-J-jWGJWcpemEXIwHc_3w4YEJrj-83NUTBFAohY-
X_xKW47Jf5oQLKRmUe8RAb9I4VQU8GshnwILGOQVSCmhfxPBzdreONmvrff6JybGI46z_OcV8L3w8UhXh0Zxiv_0BXr99dXwn3NJ
YFe9en4jv8Qu90CYsKNO1j1z_gTSwJfZWpLUD5Ej7ps3AAbThMXBkUXRymZPa9m-
UHzDp0NTNQL_JIV3XmxjJSWCGhbtd4DkwFQTo3HMHZ9wDsyz91YnAxAUjXW-7zBKlplw1dmVLsrxDuc3YANCdvWvQkSooLJN-
_3OI62844mwrCBJlmXR8cQMITj3x1sjvA
.
```

Session tokens play a key role in maintaining state in modern web applications. Conceptually, a session management system contains a collection of state variables that are stored either client- or server-side, and session tokens (also collectively called session identifiers or session IDs) are used as the "key" to access these state variables. Session tokens can be placed in cookies, query/post parameters or other HTTP headers and can be comprised of a single token or referenced in aggregate as a collection of multiple tokens.

Session tokens enable a web application to track an authenticated user's activities, correlate requests sent by that user, and provide appropriate services to the user accordingly. When a user successfully authenticates to a web application, the web application usually associates the user's identity with session tokens and accesses user data by referencing these tokens. Thus, weaknesses in deploying session tokens in a web application can be exploited by malicious attackers to hijack user sessions and compromise data confidentiality, integrity and availability.

Execution:

N/A

Implication:

When session tokens are accessible to malicious attackers by way of a vulnerable implementation, they can break into the corresponding login sessions and steal or tamper with sensitive user data. In particular, if these session tokens are tied to an administrative account, the whole website, including user accounts and the data stored within, is at serious risk of compromise.

Fix:

N/A

Reference:

Session Management:

<http://msdn.microsoft.com/en-us/library/aa478989.aspx>

ASP.NET Session State Overview:

[http://msdn.microsoft.com/en-us/library/ms178581\(v=vs.100\).aspx](http://msdn.microsoft.com/en-us/library/ms178581(v=vs.100).aspx)

Maintaining Client State using Java Servlet Technology:

http://java.sun.com/j2ee/tutorial/1_3-fcs/doc/Servlets11.html

PHP Sessions

<http://php.net/manual/en/features.sessions.php>

OWASP Session Management Cheat Sheet:

https://www.owasp.org/index.php/Session_Management_Cheat_Sheet

Attack Request:

```
POST / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: https://bizsmsraz.telekom.rs/
Content-Type: application/x-www-form-urlencoded
Content-Length: 200
Origin: https://bizsmsraz.telekom.rs
Connection: keep-alive
Pragma: no-cache
Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-Ic8mUQUmI6XbgvPvNk1;CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="64a68f9e";thid="640";

__RequestVerificationToken=QIQ8mRUTN0iee6LdzuqQ6IszC6bfJ04waM0QZzJhxle-
QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZCI39FMpTfTi5TmPqXQjCKNKZ881&Username=marijamar&Password=Marijamar
k%21%2123&RememberMe=false
```

Attack Response:

```
HTTP/1.1 302 Found
Cache-Control: no-cache
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Expires: -1
Location: /Account/VerifyPhoneNumber?phoneNumber=0641839461&provider=Phone%20Code
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-AspNet-Version: 4.0.30319
Set-Cookie: .AspNet.TwoFactorCookie=mQcyi1JygR6d2060SIQr-mZVWLLIUPxKLijk-aiejXpayJLljraKV2krl5U39RA9mnwSk2y7bkSGE0y6B5BGyP7Bk7FtLuMpaHTZe9uYts7EuB_ND0PnkmVykrBRHXCe358fXqPN9_sai
u-TZLTU3-MSQ_0DxrG5NVZn1SYShNow3x-haTJs3c2-WOSTngsDLJiz59t4rQUADGYabdwTqu5pNxPIUuwCLP-
dumObzeUdrSdRnr6lC7v5ElrWhpFIRIVxo5VNsY-N8PFIIn88x3Xfq-kVWw-
jBLPOxpX8ptDDVr05iX4zdFs_9wVEwPSE2cmV5CYZFIOgiEavda-gimQ; path=/; secure; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:48:51 GMT
Content-Length: 192

<html><head><title>Object moved</title></head><body>
<h2>Object moved to <a href="/Account/VerifyPhoneNumber?phoneNumber=0641839461&provider=Phone%
20Code">here</a>.</h2>
</body></html>
```

File Names: ● <https://bizsmsraz.telekom.rs:443/>

Informational	Insecure Deployment: Known Technology Fingerprint
Summary:	
WebInspect has determined that the target server supports the following TLS_RSA ciphers:	
• TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d) • TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)	

While TLS_RSA itself is not vulnerable, several implementations of TLS_RSA cipher have been shown to be vulnerable to

ROBOT Attack (Return Of Bleichenbacher's Oracle Threat). Bleichenbacher's is an adaptive chosen-ciphertext attack on the RSA PKCS#1v1.5 encryption standard. The vulnerability in the implementation of the RSA PKCS#1v1.5 algorithm allows an attacker to steal the private session key from a secure SSL/TLS session. The attacker can then use the key to compromise and decrypt recorded SSL/TLS sessions, leading to information disclosure and impersonation attacks.

Execution:

A list of ciphers supported by this server can be obtained by running ServerAnalyzer tool from the WebInspect toolkit. Note the presence of "TLS_RSA" ciphers in the list of supported ciphers.

Implication:

If a vulnerable version of the TLS_RSA exists on the server, the server may be vulnerable to ROBOT Attack which would allow an attacker to successfully decrypt a previously recorded SSL/TLS session, leading to information disclosure and impersonation attacks.

Fix:

Please refer to your vendor's documentation to check if the TLS_RSA version in use is vulnerable to ROBOT attack. If necessary please apply the required patch from the vendor to protect against this vulnerability.

Reference:

[The ROBOT Attack
Return Of Bleichenbacher's Oracle Threat](#)

Attack Request:

```
GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
```

Attack Response:

```
HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
Set-Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUMI6XbgvPvNk1; path=/; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:48:49 GMT
Content-Length: 4713

<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Prijava</title>
  <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

  <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>
```

```

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">

          </ul>

        <ul class="nav navbar-nav navbar-right">

          <li><a href="/" id="loginLink">Prijava</a></li>
          <li style="padding-bottom:11px; padding-top:11px;">|</li>
          <li>
            <a href="/Home/SetCulture?culture=en-us">
              <span class="flag-icon flag-icon-gb"></span>
            </a>
          </li>
        </ul>
      </div>
    </div>
    <div class="container body-content">

      <h2>Prijava</h2>
      <div class="row">
        <div class="col-md-12">
          <section id="loginForm">
            <form action="/" class="form-horizontal" method="post" role="form"><input name="__RequestVerificationToken"
            type="hidden" value="QIQ8mRUTN0iee6LdzuqQ6IszC6bfJO4waM0QZzJhxle-
            QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZCI39FMpTFTi5TmPXqjCKNKZ881" />          <hr />
            <div class="form-group">
              <label class="col-md-2 control-label" for="Username">Korisničko ime</label>
              <div class="col-md-10">
                <input class="form-control" data-val="true" data-val-required="Korisničko ime je obavezno polje"
                id="Username" name="Username" type="text" value="" />
                <span class="field-validation-valid text-danger" data-valmsg-for="Username" data-valmsg-
                replace="true"></span>
              </div>
            </div>
            <div class="form-group">
              <label class="col-md-2 control-label" for="Password">Lozinka</label>
              <div class="col-md-10">
                <input class="form-control" data-val="true" data-val-required="Lozinka je obavezno polje" id="Password"
                name="Password" type="password" />
                <span class="field-validation-valid text-danger" data-valmsg-for="Password" data-valmsg-
                replace="true"></span>
              </div>
            </div>
            <div class="form-group">
              <div class="col-md-offset-2 col-md-10">
                <div class="checkbox">
                  <input data-val="true" data-val-required="The Zapamti me? field is required." id="RememberMe"
                  name="RememberMe" type="checkbox" value="true" /><input name="RememberMe" type="hidden" value="false" />
                  <label for="RememberMe">Zapamti me?</label>
                </div>
              </div>
            </div>
            <div class="form-group">
              <div class="col-md-offset-2 col-md-10">
                <input type="submit" value="Prijava" class="btn btn-default" />
              </div>
            </div>
          </section>
        </div>
      </div>
    </div>
  </div>
  ...TRUNCATED...

```

Informational

HLI: Detected Libraries

Summary:

Hacker Level Insights provides developers and security professionals with more context relating to the overall security posture of their application. The **jQuery** version **1.11.0** was detected to be in use by during this scan. While these findings do not necessarily represent a security vulnerability, it is important to note that attackers commonly perform reconnaissance of their target in an attempt to identify known weaknesses or patterns. Knowing what the hacker can see provides context which can help teams better secure their applications.

```
.cvc-grid {width:100%;}.cvc-box {border-radius: 15px; border: 2px solid #1a75ff; width: 100%; padding: 10px;}.cvc-cat {position: relative; display: inline-block; border-bottom: 1px dotted black;}.cvc-cat .nvd-tooltip {visibility: hidden; width: 400px; background-color: #3b96ff; color: #fff; text-align: left; border-radius: 6px; padding: 5px; position: absolute; z-index: 1;}.cvc-cat:hover .nvd-tooltip {visibility: visible;}.score-box{color:#000!important;background-color:#f1f1f1!important;width:75%;border-radius:8px}.score-box div {border-radius:8px}.score-box div div{padding-left: 10px; font-weight: bold;}.score-box > div:after,.score-box > div:before {content:""; display:table;clear:both}.sb-good{color:#fff!important;background-color:#87e547!important}.sb-warn{color:#fff!important;background-color:#fbc02d!important}.sb-bad {color:#fff!important;background-color:#ff8686!important}.nvd-tooltip:before{content:"The National Vulnerability Database (NVD) helps OpenText DAST HLI analysis to find information for CVEs including a brief summary by using Common Platform Enumeration(CPE) queries. The database is maintained by the National Institute of Standards and Technology (NIST)."}

```

Known NVD records for: cpe:2.3:a:jquery:jquery:1.11.0

	FOUND VERSION:	FIXED VERSION:	SEVERITY:
VULNERABILITY:	1.11.0	3.0.0	Medium
	CVE-2015-9251		

jQuery before 3.0.0 is vulnerable to Cross-site Scripting (XSS) attacks when a cross-domain Ajax request is performed without the dataType option, causing text/javascript responses to be executed.

	FOUND VERSION:	FIXED VERSION:	SEVERITY:
VULNERABILITY:	1.11.0	3.4.0	Medium
	CVE-2019-11358		

jQuery before 3.4.0, as used in Drupal, Backdrop CMS, and other products, mishandles jQuery.extend(true, {}, ...) because of Object.prototype pollution. If an unsanitized source object contained an enumerable __proto__ property, it could extend the native Object.prototype.

	FOUND VERSION:	FIXED VERSION:	SEVERITY:
VULNERABILITY:	1.11.0	3.5.0	Medium
	CVE-2020-11023		

In jQuery versions greater than or equal to 1.0.3 and before 3.5.0, passing HTML containing <option> elements from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.

	FOUND VERSION:	FIXED VERSION:	SEVERITY:
VULNERABILITY:	1.11.0	3.5.0	Medium
	CVE-2020-11022		

In jQuery versions greater than or equal to 1.2 and before 3.5.0, passing HTML from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.

Attack Request:

GET /Home/Index HTTP/1.1
Referer: https://bizsmsraz.telekom.rs/

Accept: /*/*
Pragma: no-cache
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Host: bizsmsraz.telekom.rs
Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
Category="Crawl";SID="E2DBD255D19069FD1BD079EA033E29C1";PSID="43E189321BF5CEBC34DB4BA63F0824DE";Session
Type="Crawl";CrawlType="HTML";AttackType="None";OriginatingEngineID="00000000-0000-0000-0000-
000000000000";AttributeName="href";Format="Relative";LinkKind="HyperLink";Locations="HtmlNode";NodeName="a";Sourc
e="StaticParser";tht="31";
X-RequestManager-Memo: stid="1113";stmi="0";sc="1";rid="993c9474";
X-Request-Memo: rid="45041920";sc="1";thid="565";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=vdo9iRP2ld
89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-
lc8mUQUmI6XbgvPvNk1;.AspNet.ApplicationCookie=tk1Tj-x-
PoW1x93e5uD2dC4TV2UwYVhp1eWCGbzcEWZGCIrT3nCWlWLeHyK2fjxuB6FMe-
PUku7qTco70stH5utNPSIrS5TmFbcbbODY8w3wuhVP8QX1A0itUqchYKK0j_z5HVRHqKF4CEq3mZXpTOOIq8vvz1ctpO1HBzn-
iXeOd4EmSrR7XTog-Xx_FfmAXcxKszNR23k0dhTHu3GhznYpiwFRVazFso1QgGQkJ4dHzO-
AvxGKoKD3CEeNqOos4NAQB8wb4ValRtSP3RoypoXEnUSZsFXekiCoThknY7XdaT-oAs0T-
jgbEFtnYREHQScJ6jpFfJ1a3nRuEcUS58eSa_fu303PBiqOFzsW7kipigde6iF38gtJas7TRf7GMO8e_TVjyxkfK-
Lg21sM1XzfqZiyQaqdJLAvDEo0ysg3vvvVq_G2LP9lNoS4RojBaISRobXCzeA3jGYnEkunFZh1TXWMldQTL2trWASuNep8Pj1TWG2gF
9AcumKjbm

Attack Response:

HTTP/1.1 200 OK
Cache-Control: private, s-maxage=0
Content-Type: text/html; charset=utf-8
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:49:23 GMT
Content-Length: 7246

<!DOCTYPE html>
<html>
<head>
 <meta charset="utf-8" />
 <meta name="viewport" content="width=device-width, initial-scale=1.0">
 <title>Početna strana</title>
 <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

 <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>

</head>
<body>
 <div class="navbar navbar-inverse navbar-fixed-top">
 <div class="container">
 <div class="navbar-header">

 BizSMS
 </div>
 <div class="navbar-collapse collapse">
 <ul class="nav navbar-nav">
 Pošalji SMS
 Grupe
 Brojevi
 Mese9?ni izveštaj
 Izveštaj o poslatim SMS porukama

 <form action="/Account/LogOff" class="navbar-right" id="logoutForm" method="post"><input
name="__RequestVerificationToken" type="hidden" value="AwVQjHES7ssudgobXiO9KshcfQZ-

```
UzvMAMfw_7CklvX_j96A6v3xPRqizCWwibL-
z8JZ0j9lphNjU4UzyMzrcbrQCJR4vbMu_qmnR9EC15F_chvSHxpKOAao9EoRaeIKAlvUm9j37-8Utf-CzF7tQ2" />      <ul
class="nav navbar-nav navbar-right">
  <li class="dropdown">
    <a href="#" class="dropdown-toggle" data-toggle="dropdown" role="button" aria-haspopup="true" aria-
expanded="false"> Dobrodošli marijemark <span class="caret"></span></a>
    <ul class="dropdown-menu">
      <li><a href="/Manage/ChangePassword" title="Izmeni lozinku">Izmeni lozinku</a></li>

      <li><a href="/Home/DownloadManual" target="_blank" title="Uputstvo">Uputstvo</a></li>

    </ul>
  </li>
  <li role="separator" class="divider"></li>
  <li><a href="javascript:document.getElementById('logoutForm').submit()">Odjava</a></li>
</ul>
</li>

</ul>
</form>
</div>
</div>
</div>
<div class="container body-content">

<div class="jumbotron">
  <h1>BizSMS</h1>
  <p class="lead">Šaljite SMS poruke na brojeve telefona unutar i izvan svoje Biznet grupe</p>
</div>
<div class="form-horizontal">
  <div class="row">
    <div class="col-md-12">
      <div class="col-md-1"></div>
      <div class="col-md-2 img-transform">
        <div class="img-transform" style="text-align:center;">
          <a href="/Home/SendSMS">
            
            <span style="margin:0 auto;">SMS</span>
          </a>
        </div>
      </div>
      <div class="col-md-2">
        <div class="img-transform" style="text-align:center;">
          <a href="/Group/Index">
            
            <span style="margin:0 auto;">Grupe</span>
          </a>
        </div>
      </div>
      <div class="col-md-2">
        <div class="img-transform" style="text-align:center;">
          <a href="/Group/ListNumbers">
            <img src="/Content/img/brojev
```

...TRUNCATED...

- File Names:**
- https://bizsmsraz.telekom.rs:443/Home/Index
 - https://bizsmsraz.telekom.rs:443/Home/Index
 - https://bizsmsraz.telekom.rs:443/Home/SendSMS

Informational

Cross-Frame Scripting

Summary:

A Cross-Frame Scripting (XFS) vulnerability can allow an attacker to load the vulnerable application inside an HTML iframe tag on a malicious page. The attacker could use this weakness to devise a Clickjacking attack to conduct phishing, frame sniffing,

social engineering or Cross-Site Request Forgery attacks.

Clickjacking

The goal of a Clickjacking attack is to deceive the victim (user) into interacting with UI elements of the attacker's choice on the target web site without their knowledge and then executing privileged functionality on the victim's behalf. To achieve this goal, the attacker must exploit the XFS vulnerability to load the attack target inside an iframe tag, hide it using Cascading Style Sheets (CSS) and overlay the phishing content on the malicious page. By placing the UI elements on the phishing page so they overlap with those on the page targeted in the attack, the attacker can ensure that the victim must interact with the UI elements on the target page not visible to the victim.

An effective frame-busting technique was not observed while loading this page inside a frame.

Fix:

Developers must use client-side frame busting JavaScript as a protection against XFS in case they support the use of extremely old browsers (e.g. Internet Explorer). This will enable users of older browsers that do not support the X-Frame-Options header to also be protected from Clickjacking attacks.

Reference:

A Study of Clickjacking Vulnerabilities on Popular Sites
<http://crypto.stanford.edu/~dabo/pubs/papers/framebust.pdf>

OWASP: Clickjacking
<https://www.owasp.org/index.php/Clickjacking>

Attack Request:

```
GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443
```

Attack Response:

```
HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
Set-Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjlhIa4oTr0yPtt-lc8mUQUMI6XbgvPvNk1; path=/; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:48:49 GMT
Content-Length: 4713

<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
```

```

<title>Prijava</title>
<link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

<script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">

          </ul>

        <ul class="nav navbar-nav navbar-right">

          <li><a href="/" id="loginLink">Prijava</a></li>
          <li style="padding-bottom:11px; padding-top:11px;"></li>
          <li>
            <a href="/Home/SetCulture?culture=en-us">
              <span class="flag-icon flag-icon-gb"></span>
            </a>
          </li>
        </ul>

      </div>
    </div>
  </div>
  <div class="container body-content">

    <h2>Prijava</h2>
    <div class="row">
      <div class="col-md-12">
        <section id="loginForm">
          <form action="/" class="form-horizontal" method="post" role="form"><input name="__RequestVerificationToken"
            type="hidden" value="QIQ8mRUTN0iee6LdzuqQ6IszC6bfJO4waM0QZzJhxle-
            QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZCI39FMpTfTi5TmPXQjCKNKZ881" />          <hr />
          <div class="form-group">
            <label class="col-md-2 control-label" for="Username">Korisničko ime</label>
            <div class="col-md-10">
              <input class="form-control" data-val="true" data-val-required="Korisničko ime je obavezno polje"
                id="Username" name="Username" type="text" value="" />
              <span class="field-validation-valid text-danger" data-valmsg-for="Username" data-valmsg-
                replace="true"></span>
            </div>
          </div>
          <div class="form-group">
            <label class="col-md-2 control-label" for="Password">Lozinka</label>
            <div class="col-md-10">
              <input class="form-control" data-val="true" data-val-required="Lozinka je obavezno polje" id="Password"
                name="Password" type="password" />
              <span class="field-validation-valid text-danger" data-valmsg-for="Password" data-valmsg-
                replace="true"></span>
            </div>
          </div>
          <div class="form-group">
            <div class="col-md-offset-2 col-md-10">
              <div class="checkbox">
                <input data-val="true" data-val-required="The Zapamti me? field is required." id="RememberMe"
                  name="RememberMe" type="checkbox" value="true" /><input name="RememberMe" type="hidden" value="false" />
                <label for="RememberMe">Zapamti me?</label>
              </div>
            </div>
          </div>
          <div class="form-group">
            <div class="col-md-offset-2 col-md-10">
              <input type="submit" value="Prijava" class="btn btn-default" />
            </div>
          </div>
        </section>
      </div>
    </div>
  </div>

```

</div>
</div>

...TRUNCATED...

- File Names:**
- <https://bizsmsraz.telekom.rs:443/>
 - <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/206000>

Informational

Insecure Transport: Missing PQC Resilient Key Exchange

Summary:

WebInspect could not negotiate quantum-resistant key exchange algorithm: X25519MLKEM768.

The absence of post-quantum cryptography (PQC) support in TLS 1.3 configurations leaves encrypted communications rely solely on classical key exchange algorithms, such as X25519 or secp256r1. While these algorithms currently resist conventional attacks, quantum computers threaten their future security. If large-scale quantum computers become practical, adversaries could break these classical key exchanges, potentially exposing the confidentiality of data encrypted today. One of the current risks is the idea of "harvest now, decrypt later," where adversaries record encrypted traffic now and decrypt it in the future.

Execution:

To verify this finding, follow these steps:

Packet Capture

- Start a packet capture tool (e.g. Wireshark, tcpdump)
- Filter for TLS Traffic: `tls.handshake.type==1` or `tls.handshake.type==2`

Rerun this check (ID: 11770) or visit the <https://bizsmsraz.telekom.rs:443/> from a modern browser (Chrome, Firefox, Edge etc.)

ClientHello Analysis

- Locate the extensions in ClientHello packet.
- ClientHello advertises X25519MLKEM768 support.
- Verify whether X25519MLKEM768 is present in the Extension: `supported_groups (10)` and Extension: `key_share (51)` contains 1216-byte key for hybrid group.

ServerHello Response Analysis

- Locate the extensions in ServerHello packet.
- Check if server selects the new hybrid key exchange.
- If server selects a classical group (such as `x25519` or `secp256r1`) or issues a `HelloRetryRequest`, this confirms the absence of PQC support.

Implication:

Attackers may capture and harvest encrypted traffic today and decrypt it in the future once more quantum capabilities are available. This would compromise the confidentiality of sensitive data.

Fix:

- Inventory current TLS 1.3 implementation and server software versions to understand PQC support capabilities.
- Monitor vendor announcements for PQC support updates, including OpenSSL releases, web server software updates, and hybrid key exchange algorithm availability.
- Configure test environments with TLS 1.3 and hybrid key exchange groups to validate PQC functionality.
- Sample configurations

Apache:
`SSLProtocol TLSv1.3`

SSLOpenSSLConfCmd Groups X25519MLKEM768:X25519:secp256r1

Nginx:

```
ssl_protocols TLSv1.3;  
ssl_conf_command Groups X25519MLKEM768:X25519:secp256r1;
```

OpenSSL Client Testing:

```
openssl s_client -connect <host>:<port> -groups X25519MLKEM768:X25519 -tls1_3
```

- Test application compatibility and performance impact of hybrid key exchange algorithms in staging environments.
- Develop a phased migration timeline prioritizing high-value data systems, considering quantum threat timelines and organizational risk tolerance, then deploy PQC configurations to production environments with proper rollback procedures.

Reference:

NIST Post-Quantum Cryptography Project

<https://csrc.nist.gov/projects/post-quantum-cryptography>

Post-Quantum Cryptography Standards - NIST FIPS 203, 204, 205

<https://csrc.nist.gov/Projects/post-quantum-cryptography/post-quantum-cryptography-standardization>

Cloudflare Post-Quantum Cryptography Implementation Guide

<https://www.cloudflare.com/pqc/>

Akamai Post-Quantum Cryptography Implementation Considerations in TLS

<https://www.akamai.com/us/en/resources/white-papers/post-quantum-cryptography-implementation-considerations-in-tls.pdf>

RFC 9180: Hybrid Public Key Encryption (HPKE)

<https://datatracker.ietf.org/doc/html/rfc9180>

QUBIP - Quantum Computers' Role in Shor's Algorithm

<https://qubip.eu/the-role-of-quantum-computers-in-shors-algorithm/>

Attack Request:

GET / HTTP/1.1

Host: bizsmsraz.telekom.rs

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0

Accept: */*

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate

Connection: keep-alive

Sec-Fetch-Dest: document

Sec-Fetch-Mode: navigate

Sec-Fetch-Site: same-origin

Priority: u=0, i

X-WIPP: AscVersion=25.4.0.57

X-RequestManager-Memo: std="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";

X-Request-Memo: rid="7810b0c4";thid="601";

Pragma: no-cache

Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443

Attack Response:

HTTP/1.1 200 OK

Cache-Control: public, no-store, max-age=0

Content-Type: text/html; charset=utf-8

Expires: Thu, 16 Apr 2026 06:48:49 GMT

Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT

Vary: *

Server: Microsoft-IIS/10.0

X-AspNetMvc-Version: 5.2

X-Frame-Options: SAMEORIGIN

X-AspNet-Version: 4.0.30319

Set-Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; path=/; HttpOnly

X-Powered-By: ASP.NET

Strict-Transport-Security: max-age=31536000; includeSubDomains

Date: Thu, 16 Apr 2026 06:48:49 GMT

Content-Length: 4713

```

<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Prijava</title>
  <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

  <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">

          </ul>

        <ul class="nav navbar-nav navbar-right">

          <li><a href="/" id="loginLink">Prijava</a></li>
          <li style="padding-bottom:11px; padding-top:11px;">|</li>
          <li>
            <a href="/Home/SetCulture?culture=en-us">
              <span class="flag-icon flag-icon-gb"></span>
            </a>
          </li>
        </ul>

      </div>
    </div>
  </div>
  <div class="container body-content">

    <h2>Prijava</h2>
    <div class="row">
      <div class="col-md-12">
        <section id="loginForm">
          <form action="/" class="form-horizontal" method="post" role="form"><input name="__RequestVerificationToken"
            type="hidden" value="QIQ8mRUTN0iee6LdzuqQ6IszC6bfJO4waM0QZzJhxl-
            QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZCI39FMpTFTi5TmPXqJCKNKZ881" />          <hr />
          <div class="form-group">
            <label class="col-md-2 control-label" for="Username">Korisničko ime</label>
            <div class="col-md-10">
              <input class="form-control" data-val="true" data-val-required="Korisničko ime je obavezno polje"
                id="Username" name="Username" type="text" value="" />
              <span class="field-validation-valid text-danger" data-valmsg-for="Username" data-valmsg-
                replace="true"></span>
            </div>
          </div>
          <div class="form-group">
            <label class="col-md-2 control-label" for="Password">Lozinka</label>
            <div class="col-md-10">
              <input class="form-control" data-val="true" data-val-required="Lozinka je obavezno polje" id="Password"
                name="Password" type="password" />
              <span class="field-validation-valid text-danger" data-valmsg-for="Password" data-valmsg-
                replace="true"></span>
            </div>
          </div>
          <div class="form-group">
            <div class="col-md-offset-2 col-md-10">
              <div class="checkbox">
                <input data-val="true" data-val-required="The Zapamti me? field is required." id="RememberMe"
                  name="RememberMe" type="checkbox" value="true" /><input name="RememberMe" type="hidden" value="false" />
                <label for="RememberMe">Zapamti me?</label>
              </div>
            </div>
          </div>
        </section>
      </div>
    </div>
  </div>

```

```

    </div>
  </div>
  <div class="form-group">
    <div class="col-md-offset-2 col-md-10">
      <input type="submit" value="Prijava" class="btn btn-default" />
    </div>
  </div>
</div>

```

...TRUNCATED...

File Names: ● <https://bizsmsraz.telekom.rs:443/>

Best Practice

Compliance Failure: Missing Privacy Policy

Summary:

A privacy policy was not supplied by the web application within the scope of this audit. Many legislative initiatives require that organizations place a publicly accessible document within their web application that defines their website's privacy policy. As a general rule, these privacy policies must detail what information an organization collects, the purpose for collecting it, potential avenues of disclosure, and methods for addressing potential grievances.

Various laws governing privacy policies include the Gramm-Leach-Bliley Act, Health Insurance Portability and Accountability Act (HIPAA), the California Online Privacy Protection Act of 2003, European Union's Data Protection Directive and others.

Execution:

All of the web pages accessible within the scope of the scan are sampled for textual content that often constitutes a privacy policy statement. A violation is reported upon completion of the web application crawl without a successful match against any of the web pages.

Note that the privacy policy of your application could be located on another host or within a section of the site that was not configured as part of the scan. To validate, please try to access the privacy policy of your website and check to see if it was part of the scan.

Implication:

Most privacy laws are created to protect residents who are users of the website. Hence, organizations from any part of the world must adhere to these laws if they cater to customers residing in these geographical areas. Failing to do so could result in a lawsuit by the corresponding government against the organization.

Fix:

Declare a comprehensive privacy policy for the website, and ensure that it is accessible from every page that seeks personal information from users. To verify the fix, rescan the site in order to discover and audit the newly added resources.

Descriptions:

Any standard web application privacy policy should include the following components:

- A description of the intended purpose for collecting the data.
- A description of the use of the data.
- Methods for limiting the use and disclosure of the information.
- A list of the types of third parties to whom the information might be disclosed.
- Contact information for inquires and complaints.

Reference:

California Online Privacy Protection Act

<http://oag.ca.gov/privacy/COPPA>

National Conference of State Legislation

<http://www.ncsl.org/issues-research/telecom/state-laws-related-to-internet-privacy.aspx>

Gramm-Leach-Bliley Act

<http://www.gpo.gov/fdsys/pkg/PLAW-106publ102/pdf/PLAW-106publ102.pdf>

Health Insurance Portability and Accountability Act of 1996

<https://www.cms.gov/Regulations-and-Guidance/HIPAA-Administrative-Simplification/HIPAAGenInfo/downloads/HIPAALaw.pdf>

Health Insurance Portability and Accountability Act of 1996

http://ec.europa.eu/justice/policies/privacy/docs/guide/guide-ukingdom_en.pdf

Attack Request:

GET / HTTP/1.1

Accept: */*

Pragma: no-cache

Accept-Encoding: gzip, deflate

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0

Host: bizsmsraz.telekom.rs
Connection: Keep-Alive
X-WIPP: AscVersion=25.4.0.57
X-Scan-Memo:
Category="Crawl";SID="43E189321BF5CEBC34DB4BA63F0824DE";SessionType="ExternalAddedToCrawl";CrawlType="None";
AttackType="None";OriginatingEngineID="00000000-0000-0000-0000-000000000000";tht="31";
X-RequestManager-Memo: stid="1113";stmi="0";sc="1";rid="da5c5984";
X-Request-Memo: rid="d9a3729a";sc="1";thid="595";
Cookie:
CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443;__RequestVerificationToken=vdo9iRP2ld
89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIh1a4oTr0yPtt-
lc8mUQUmI6XbgvPvNk1;.AspNet.ApplicationCookie=tk1Tj-x-
PoW1x93e5uD2dC4TV2UwYVhp1eWCGbzcEWZGciRieT3nCwIwLeHyK2fjxuB6FMe-
PUku7qTco70stH5utNPSIrS5TmFbcbbODY8w3wuhVP8QX1A0itUqchYKK0j_z5HVRHqKF4CEq3mZXpTOOIq8vvz1ctpO1HBzn-
iXeOd4EmSrR7XTog-Xx_FfmAXcxKszNR23k0dhTHu3GhznYpiwFRVazFso1QgGQkJ4dHzO-
AvxGKoKD3CEeNqOos4NAQB8wb4ValRtSP3RoypoXEnUSZsFXekiCoThknY7XdaT-oAs0T-
jgbEFtnYREHQScJ6jpFfJ1a3nRuEcUS58eSa_fu303PBiQOFzSW7kipigde6iF38gtJas7TRf7GMO8e_TVjyxkfK-
Lg21sM1XzfQZiyQaqdJLAvDEo0ysg3vvvVq_G2LP9lNoS4RojBaISRobXCzeA3jGYNekunFZh1TXWMldQTL2trWASuNep8Pj1TWG2gF
9AcumKjbm

Attack Response:

HTTP/1.1 302 Found
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:57 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:57 GMT
Location: /Home/Index
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:48:57 GMT
Content-Length: 128

<html><head><title>Object moved</title></head><body>
<h2>Object moved to here.</h2>
</body></html>

File Names: ● https://bizsmsraz.telekom.rs:443/

Best Practice Privacy Violation: Autocomplete

Summary:

Most recent browsers have features that will save form field content entered by users and then automatically complete form entry the next time the fields are encountered. This feature is enabled by default and could leak sensitive information since it is stored on the hard drive of the user. The risk of this issue is greatly increased if users are accessing the application from a shared environment. Recommendations include setting autocomplete to "off" on all your forms.

Reference:

Microsoft:
[Autocomplete Security](#)

Attack Request:

GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443

Attack Response:

HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
Set-Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxfeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; path=/; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:48:49 GMT
Content-Length: 4713

```
<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Prijava</title>
  <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

  <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">

          </ul>

        <ul class="nav navbar-nav navbar-right">

          <li><a href="/" id="loginLink">Prijava</a></li>
          <li style="padding-bottom:11px; padding-top:11px;">|</li>
          <li>
            <a href="/Home/SetCulture?culture=en-us">
              <span class="flag-icon flag-icon-gb"></span>
            </a>
          </li>
        </ul>

      </div>
    </div>
  </div>
  <div class="container body-content">
```



```

<h2>Prijava</h2>
<div class="row">
  <div class="col-md-12">
    <section id="loginForm">
      <form action="/" class="form-horizontal" method="post" role="form"><input name="__RequestVerificationToken"
type="hidden" value="QIQ8mRUTN0iee6LdzuqQ6IszC6bfJO4waM0QZzJhxle-
QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZCI39FMpTFTi5TmpXQjCKNKZ881" />          <hr />
        <div class="form-group">
          <label class="col-md-2 control-label" for="Username">Korisničko ime</label>
          <div class="col-md-10">
            <input class="form-control" data-val="true" data-val-required="Korisničko ime je obavezno polje"
id="Username" name="Username" type="text" value="" />
            <span class="field-validation-valid text-danger" data-valmsg-for="Username" data-valmsg-
replace="true"></span>
          </div>
        </div>
        <div class="form-group">
          <label class="col-md-2 control-label" for="Password">Lozinka</label>
          <div class="col-md-10">
            <input class="form-control" data-val="true" data-val-required="Lozinka je obavezno polje" id="Password"
name="Password" type="password" />
            <span class="field-validation-valid text-danger" data-valmsg-for="Password" data-valmsg-
replace="true"></span>
          </div>
        </div>
        <div class="form-group">
          <div class="col-md-offset-2 col-md-10">
            <div class="checkbox">
              <input data-val="true" data-val-required="The Zapamti me? field is required." id="RememberMe"
name="RememberMe" type="checkbox" value="true" /><input name="RememberMe" type="hidden" value="false" />
              <label for="RememberMe">Zapamti me?</label>
            </div>
          </div>
        </div>
        <div class="form-group">
          <div class="col-md-offset-2 col-md-10">
            <input type="submit" value="Prijava" class="btn btn-default" />
          </div>
        </div>
      </section>
    </div>
  </div>
</div>
...TRUNCATED...

```

File Names:

- <https://bizsmsraz.telekom.rs:443/>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/206000>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/206002>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/206001>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205999>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205998>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205997>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205996>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205995>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205994>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205993>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205992>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205991>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/205990>
- <https://bizsmsraz.telekom.rs:443/bundles/custom?v=D92H56rQB1a-SyJSzx3-vvqKEbrjLB59At3fs-ZuS3g1>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212798>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/206004>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/206003>

- [illegible]

- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213043>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213042>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213041>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/49238>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213040>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213063>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213039>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213136>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213038>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/301312>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213037>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213055>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213036>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/295969>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213035>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/255484>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213034>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/255887>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213033>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/297112>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213032>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/297473>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213031>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213030>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213121>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213029>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213028>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213027>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213026>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213025>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212843>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212842>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212841>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212840>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212839>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212838>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212837>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212836>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212835>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212834>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212833>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212832>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212831>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212830>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212829>

- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212828>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/212827>
- <https://bizsmsraz.telekom.rs:443/Group/CreateGroup>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213174>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213173>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213172>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213171>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213170>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213169>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213168>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213167>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213166>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213165>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213164>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213163>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213150>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213149>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213148>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213147>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213146>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213142>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213141>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213140>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213139>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213138>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213137>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213135>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213134>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213133>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213132>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213131>
- <https://bizsmsraz.telekom.rs:443/Account/>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213130>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213129>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213128>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213127>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213126>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213125>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213124>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213123>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213122>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213120>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213119>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213118>

- [illegible]

- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213070>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213069>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213068>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213067>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213066>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213065>
- <https://bizsmsraz.telekom.rs:443/Group/EditListNumber/213064>

Best Practice

Insecure Transport: Missing Perfect Forward Secrecy

Summary:

Perfect Forward Secrecy (PFS) assures the secrecy of encrypted communications into the future in case SSL/TLS private key is compromised. PFS is a function of key-exchange protocols used for the establishment of shared secret between the client and the server [1]. On a non-forward secrecy server, both the authentication of the server and the encryption is done using long-term private key. Hence, compromised long-term private key can jeopardize all communications. PFS mitigates this by achieving authentication using a long-term private key and session data encryption using a short-term private key. PFS is commonly achieved using Diffie-Hellman in ephemeral-static mode (DHE) or Elliptic Curve Diffie-Hellman key agreement scheme with ephemeral keys (ECDHE) [2, 3, 4]. For every TLS session established with DHE- or ECDHE- as key exchange algorithm in cipher suite, the server is required to use a new Diffie-Hellman public/private key for the generation of the TLS master secret [8]. The server signs this Diffie-Hellman public key using the long-term private key to guarantee authenticity. The long-term private key is not used for the encryption of session contents. While a stolen ephemeral private key could allow an attacker to decipher encrypted communication, the compromise is confined to the specific session for which the ephemeral key was generated. It is recommended that ephemeral keys are not logged.

WebInspect has determined that bizsmsraz.telekom.rs:443 target server configuration contains following issues:

1. Target server supports ECDHE PFS cipher suites but it also uses 2 other cipher suites which do not support PFS:
 - **TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)**
 - **TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)**

Execution:

A list of supported ciphers by this server can be obtained by running ServerAnalyzer tool from WebInspect toolkit. Notice the absence of "DHE" and "ECDHE" in the list of supported cipher-suite names.

Implication:

A stolen long-term private key can be used by an attacker to decrypt past intercepted communication putting user data at risk where data is still relevant. This shortcoming in SSL/TLS was accentuated in the wake of Heartbleed [4] vulnerability, a vulnerability in Openssl library[4], that allowed attackers to steal server's private keys among other sensitive data.

Fix:

1. PFS is enabled by turning on Diffie-Hellman Ephemeral (DHE) or Elliptic-Curve-Diffie-Hellman Ephemeral (ECDHE) based cipher suites on the server [2]. e.g.
 - For Apache – Modify SSLCipherSuite parameter in server configuration to add ECDHE or DHE key exchange algorithm.
 - For nginx – Modify ssl_ciphers in server configuration to add ECDHE or DHE key exchange algorithm.
 - For IIS please refer to following knowledge base articles:
 - [http://msdn.microsoft.com/en-us/library/windows/desktop/aa374757\(v=vs.85\).aspx](http://msdn.microsoft.com/en-us/library/windows/desktop/aa374757(v=vs.85).aspx)
 - <http://support.microsoft.com/kb/245030>
2. Make sure that all other cipher suites which do not provide PFS are disabled on the server.

Reference:

http://en.wikipedia.org/wiki/Forward_secrecy
 Dierks, T. and E. Rescorla, "The Transport Layer Security (TLS) Protocol Version 1.2", RFC 5246, August 2008.
 Rescorla, E., "Diffie-Hellman Key Agreement Method", RFC 2631, June 1999.
 Blake-Wilson, S., Bolyard, N., Gupta, V., Hawk, C., and B. Moeller, "Elliptic Curve Cryptography (ECC) Cipher Suites for Transport Layer Security (TLS)", RFC 4492, May 2006.
<http://tools.ietf.org/html/rfc4492>
<https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0160>
<http://www.openssl.org/>
http://en.wikipedia.org/wiki/Diffie-Hellman_key_exchange
http://nginx.org/en/docs/http/ngx_http_ssl_module.html
http://httpd.apache.org/docs/2.2/mod/mod_ssl.html

Attack Request:

GET / HTTP/1.1
Host: bizsmsraz.telekom.rs
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Priority: u=0, i
X-WIPP: AscVersion=25.4.0.57
X-RequestManager-Memo: stdid="1113";stmi="0";Category="EventMacro.StartMacro";MacroName="bizsms_2.webmacro";
X-Request-Memo: rid="7810b0c4";thid="601";
Pragma: no-cache
Cookie: CustomCookie=WebInspect214987ZX917791ADC46D4CC5BE4A5CAEE5511B95YA443

Attack Response:

HTTP/1.1 200 OK
Cache-Control: public, no-store, max-age=0
Content-Type: text/html; charset=utf-8
Expires: Thu, 16 Apr 2026 06:48:49 GMT
Last-Modified: Thu, 16 Apr 2026 06:48:49 GMT
Vary: *
Server: Microsoft-IIS/10.0
X-AspNetMvc-Version: 5.2
X-Frame-Options: SAMEORIGIN
X-AspNet-Version: 4.0.30319
Set-Cookie: __RequestVerificationToken=vdo9iRP2ld89LL4rG2ZjsdCVIz0EE1kyKSLY_2XNrb22nFKr3-9cTNxFeTw7BY8ju3sJy3PCzHjIhIa4oTr0yPtt-lc8mUQUmI6XbgvPvNk1; path=/; HttpOnly
X-Powered-By: ASP.NET
Strict-Transport-Security: max-age=31536000; includeSubDomains
Date: Thu, 16 Apr 2026 06:48:49 GMT
Content-Length: 4713

```
<!DOCTYPE html>
<html>
<head>
  <meta charset="utf-8" />
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Prijava</title>
  <link href="/Content/css?v=YXE83-P21orHpq-SEpvA04Q9ZBVbupicUtYe6DdOuO01" rel="stylesheet"/>

  <script src="/bundles/modernizr?v=wBEWDufH_8Md-Pbioxomt90vm6tJN2Pyy9u9zHtWsPo1"></script>

</head>
<body>
  <div class="navbar navbar-inverse navbar-fixed-top">
    <div class="container">
      <div class="navbar-header">

        <a class="navbar-brand" href="/Home/Index">BizSMS</a>
      </div>
      <div class="navbar-collapse collapse">
        <ul class="nav navbar-nav">

          <li><a href="/" id="loginLink">Prijava</a></li>
          <li style="padding-bottom:11px; padding-top:11px;"></li>
          <li>
            <a href="/Home/SetCulture?culture=en-us">
              <span class="flag-icon flag-icon-gb"></span>
            </a>
          </li>
        </ul>

        <ul class="nav navbar-nav navbar-right">

          <li><a href="/" id="loginLink">Prijava</a></li>
          <li style="padding-bottom:11px; padding-top:11px;"></li>
          <li>
            <a href="/Home/SetCulture?culture=en-us">
              <span class="flag-icon flag-icon-gb"></span>
            </a>
          </li>
        </ul>
      </div>
    </div>
  </div>
```

```

</ul>

</div>
</div>
</div>
<div class="container body-content">

<h2>Prijava</h2>
<div class="row">
  <div class="col-md-12">
    <section id="loginForm">
      <form action="/" class="form-horizontal" method="post" role="form"> <input name="__RequestVerificationToken"
      type="hidden" value="QIQ8mRUTN0iee6LdzuqQ6IszC6bfJO4waM0QZzJhxle-
      QLRhq20tB6zkCNsFFyOABTtSenbW9EO4qEtqZCI39FMpTFTi5TmPXqjCKNKZ881" />      <hr />
      <div class="form-group">
        <label class="col-md-2 control-label" for="Username">Korisničko ime</label>
        <div class="col-md-10">
          <input class="form-control" data-val="true" data-val-required="Korisničko ime je obavezno polje"
          id="Username" name="Username" type="text" value="" />
          <span class="field-validation-valid text-danger" data-valmsg-for="Username" data-valmsg-
          replace="true"></span>
        </div>
      </div>
      <div class="form-group">
        <label class="col-md-2 control-label" for="Password">Lozinka</label>
        <div class="col-md-10">
          <input class="form-control" data-val="true" data-val-required="Lozinka je obavezno polje" id="Password"
          name="Password" type="password" />
          <span class="field-validation-valid text-danger" data-valmsg-for="Password" data-valmsg-
          replace="true"></span>
        </div>
      </div>
      <div class="form-group">
        <div class="col-md-offset-2 col-md-10">
          <div class="checkbox">
            <input data-val="true" data-val-required="The Zapamti me? field is required." id="RememberMe"
            name="RememberMe" type="checkbox" value="true" /> <input name="RememberMe" type="hidden" value="false" />
            <label for="RememberMe">Zapamti me?</label>
          </div>
        </div>
      </div>
      <div class="form-group">
        <div class="col-md-offset-2 col-md-10">
          <input type="submit" value="Prijava" class="btn btn-default" />
        </div>
      </div>
    </div>
  </div>
</div>
...TRUNCATED...

```

File Names: ● <https://bizsmsraz.telekom.rs:443/>